GUIDE DE DÉPLOIEMENT

Intune + Defender for Business

Minimum Viable de Conformité (MVC)

PME suisse 5 à 25 personnes, Microsoft 365 Business Premium

Licence :	Microsoft 365 Business Premium (Intune et Defender for Business inclus)
Tenant :	[tenant].onmicrosoft.com (à remplacer)
Client :	[Nom du client] (à remplacer)
Durée :	4 à 5 heures de travail technique (hors périodes d'observation)
Prérequis :	Étape 0 Entra ID P1 (Parties 0 à 3) et CA-02 déployées
Version :	3.6, validation terrain en cours, novembre 2026

Table des matières

Préface
Partie 0 : Prérequis
Partie 1 : Inscription des appareils Windows
Partie 2 : Inscription des appareils mobiles
Partie 3 : Chiffrement et contrôle des périphériques
Partie 4 : Politiques Endpoint Security
Partie 5 : SmartScreen et filtrage web
Partie 6 : Investigation et réponse automatisée
Partie 7 : Gestion des vulnérabilités
Partie 7bis : Prise en main à distance
Partie 8 : Politiques de conformité
Partie 9 : Profils de configuration
Partie 10 : Defender for Office 365 Plan 1
Partie 11 : Alertes et surveillance
Partie 12 : Intégration Entra ID, CA-04 et CA-08
Partie 13 : Tests et validation
Checklist de remise client
Annexe A : Glossaire
Annexe B : Checklist MVC complète avec références nLPD
Annexe C : Références nLPD, mesures techniques couvertes
Annexe D : Adaptations sectorielles
Annexe E : Différences POC et production
Annexe F : Licences

ATTENTION remplacez `[tenant]` et `[Nom du client]` par les informations réelles du client avant toute utilisation.

INFO **état du document.** Les chemins et les libellés de ce guide ont été relevés sur le portail. Les valeurs marquées « à confirmer » n'ont pas été vérifiées, et les tests sur appareils réels (mobiles, Remote Help, retrait d'un appareil) restent à faire lors de la validation terrain : ne les appliquez pas en production sans validation.

Préface

Ce guide déploie la couche **appareils et menaces** du bundle MVC nLPD. Il complète le MVC Purview (données) et le MVC Entra ID P1 (identités). Ensemble, les trois guides forment une défense en profondeur proportionnée, au sens des mesures techniques de la nLPD art. 8.

Deux portails, un seul objectif. La configuration des appareils et de Defender se fait dans **intune.microsoft.com** (Sécurité du point de terminaison). La surveillance et Defender for Office 365 se font dans **security.microsoft.com** (Defender XDR). Ne pas confondre les deux.

Durée. 4 à 5 heures de travail technique. Les périodes d'observation (ASR, Network Protection, filtrage web, délai de grâce de conformité, mode Rapport de CA-04 et CA-08) sont du temps calendaire à prévoir dans le planning du client.

Pilier	Ce que ça apporte
Groupes d'appareils par plateforme	`GRP-Appareils-Windows`, `GRP-Appareils-iOS`, `GRP-Appareils-Android` : chaque politique cible la bonne plateforme
Connecteur Intune → Defender	Intégration EDR et partage des signaux de risque avec la conformité
BitLocker + Device Control USB	Protection des données au repos et prévention de l'exfiltration physique `[nLPD art. 8]`
Politique EDR	Détection comportementale et isolation des postes compromis `[nLPD art. 8]`
Antivirus + Tamper Protection + ASR	Protection en temps réel et réduction de la surface d'attaque `[nLPD art. 8]`
Windows LAPS	Mot de passe administrateur local unique par poste `[nLPD art. 8]`
SmartScreen + Network Protection + filtrage web	Protection de la navigation `[nLPD art. 8]`
Investigation et réponse automatisées (AIR)	Contribue à la détection et à la remédiation, avec suivi dans le Centre d'actions `[nLPD art. 8]`
Gestion des vulnérabilités	Inventaire des CVE et recommandations correctives `[nLPD art. 8]`
Conformité Intune + CA-08	Seuls les appareils conformes accèdent aux ressources M365 `[nLPD art. 8]`
Safe Links + Safe Attachments + Anti-phishing	Protection de la messagerie Exchange `[nLPD art. 8]`

INFO **nLPD art. 8 et art. 24.** Antivirus, EDR, ASR, BitLocker, Device Control, gestion des vulnérabilités et protection de la messagerie sont des mesures techniques au sens de l'art. 8. Les alertes, l'AIR et les notifications contribuent à la détection et à la documentation des incidents, dans le cadre de l'art. 8. L'art. 24 concerne l'**annonce des violations de la sécurité des données** au PFPDT : c'est une procédure organisationnelle que ces outils facilitent sans la remplacer.

INFO hors périmètre MVC : Defender for Endpoint Plan 2 (chasse aux menaces avancée), Defender for Cloud Apps (Shadow IT, guide séparé), Sentinel (SIEM, guide séparé).

INFO **prérequis Entra.** Étape 0 du guide Entra ID P1 déployée (break-glass, MFA CA-01, MFA administrateurs CA-09) et authentification héritée bloquée (CA-02). CA-04 et CA-08 sont créées en mode Rapport dans le guide Entra et passent en Application dans la Partie 12 de ce guide.

Partie 0 : Prérequis

0.1 Portails et rôles

N°	Étape	Action
1	Portails	intune.microsoft.com pour la configuration des appareils et de Defender. security.microsoft.com pour Defender for Office 365 (Safe Links, Safe Attachments, anti-phishing) et la surveillance.
2	Rôle Intune	Administrateur Intune ou Administrateur général.
3	Rôle Defender XDR	Administrateur de la sécurité pour Safe Links, Safe Attachments et anti-phishing.

ATTENTION après ajout d'un rôle, déconnectez-vous et reconnectez-vous. Les rôles ne prennent pas effet dans la session en cours.

0.2 Créer les groupes d'appareils par plateforme

Ces trois groupes ciblent les politiques de ce guide. Une politique Windows ne doit jamais être affectée à un groupe mobile, et inversement.

N°	Étape	Action
1	Chemin	entra.microsoft.com → Groupes → Tous les groupes → Nouveau groupe. Dans le formulaire : Type de groupe : Sécurité.
2	Groupe Windows	Nom de groupe : `GRP-Appareils-Windows`. Type d'appartenance : Appareil dynamique (les choix sont Affecté, Utilisateur dynamique, Appareil dynamique). Membres d'appareil dynamique → Ajouter une requête dynamique → onglet Configurer les règles → Syntaxe de la règle → Modifier : `(device.deviceOSType -eq "Windows") and (device.deviceManagementAppId -eq "0000000a-0000-0000-c000-000000000000")` → Enregistrer → Créer. Cette règle ne retient que les appareils Windows gérés par Intune (voir l'encadré ci-dessous : la règle `deviceOSType` seule inclut aussi les serveurs).
3	Groupe iOS	Nom de groupe : `GRP-Appareils-iOS`. Même procédure. La valeur de `deviceOSType` pour iPhone et iPad n'a pas pu être relevée (aucun appareil iOS dans le tenant d'essai) : à confirmer avec un appareil iOS inscrit, puis écrire la règle.
4	Groupe Android	Nom de groupe : `GRP-Appareils-Android`. Même procédure, règle : `(device.deviceOSType -eq "Android")`. Un filtre complémentaire sur l'inscription Intune (comme pour Windows) est à ajouter après vérification de la propriété sur un appareil Android réel : sa valeur n'est pas documentée ici.
5	Vérification	Après inscription d'un appareil de test par plateforme, vérifier qu'il apparaît dans le bon groupe et uniquement celui-là.

INFO **libellés vérifiés le 8 novembre 2026** sur le centre d'administration Entra (formulaire « Nouveau groupe », page « Règles d'adhésion dynamiques »). Valeurs de `deviceOSType` observées dans la liste des appareils : « Windows » et « Android ». Le générateur de règles propose les propriétés `deviceOSType`, `deviceOSVersion`, `deviceOwnership`, `enrollmentProfileName`, `managementType`, entre autres.

ATTENTION **serveurs et contrôleurs de domaine.** La règle `(device.deviceOSType -eq "Windows")` seule regroupe aussi les serveurs : Entra affiche « Windows » comme système d'exploitation d'un serveur (fiche d'un serveur hybride : système d'exploitation « Windows », GPM « Aucun »). Une politique de sécurité du point de terminaison affectée à ce groupe pourrait donc les atteindre. Le critère qui distingue les postes est le GPM : seuls les appareils inscrits à Intune ont « Microsoft Intune ». Le recalcul d'un groupe dynamique n'est pas immédiat : après la modification de la règle, le compteur de membres a mis une dizaine de minutes à se mettre à jour.

Un serveur ou un contrôleur de domaine géré par Intune entrerait dans ce groupe. Il faut l'exclure : soit en ajoutant à la règle `and (device.displayName -ne "[Nom du serveur]")`, soit, plus robuste chez un client, en le plaçant dans un groupe `GRP-Exclusion-Serveurs` ajouté en **Exclure** à l'onglet « Assignments » de chaque politique. Les serveurs se traitent par des politiques distinctes, testées en mode Audit.

L'identifiant `0000000a-0000-0000-c000-000000000000` est celui d'Intune comme GPM d'après un article communautaire (Anoop C Nair), pas d'après une page Microsoft. Il est validé en pratique sur le tenant de validation.

INFO **périmètre limité.** Si le client préfère un périmètre restreint (pilote), utilisez l'appartenance « Affecté » à la place de la règle dynamique, puis passez en dynamique après validation.

CONSEIL le groupe `GRP-USB-Autorises` (exceptions Device Control, §3.3) est créé séparément, en appartenance « Affecté », avec des utilisateurs ou des appareils nommément autorisés.

0.3 Connecter Intune à Defender for Business

IMPORTANT faites cette étape en premier. Le connecteur active l'intégration Defender (onboarding EDR, signaux de risque d'appareil utilisables par la conformité). Les politiques antivirus, pare-feu et ASR sont distribuées par le MDM d'Intune : elles ne dépendent pas du connecteur, mais le score de risque Defender de la Partie 8 et l'intégration EDR en dépendent.

N°	Étape	Action
1	Chemin	intune.microsoft.com → Administrateur de locataire → Connecteurs et jetons → section « Multiplateforme » → Microsoft Defender for Endpoint (le libellé du portail est en anglais).
2	État	Page « Connecteurs et jetons \
3	Configurations Endpoint Security	Section « Paramètres du profil de sécurité du point de terminaison » → « Autoriser Microsoft Defender for Endpoint l'application des configurations Endpoint Security » : **Activé** (valeur observée sur le tenant d'essai).
4	Évaluation de la conformité	Section « Évaluation de la stratégie de conformité » : activer la connexion des appareils Windows 10.0.15063 et ultérieurs, et, si des mobiles sont gérés, Android 6.0.0 et ultérieurs et iOS/iPadOS 13.0 et ultérieurs. Sans cela, le score de risque Defender de la Partie 8 n'est pas disponible pour ces appareils.
5	Enregistrer	Cliquer Enregistrer si une valeur a été modifiée.

INFO **libellés vérifiés le 8 novembre 2026** sur le centre d'administration Intune. La page contient aussi les sections « Protection d'applications, évaluation de la stratégie » et « Rôle de défense contre les menaces mobiles » : hors périmètre de ce guide. Un bandeau précise que, pour iOS/iPadOS, le connecteur est actif mais que l'évaluation des risques n'est pas incluse dans une stratégie de conformité par défaut : elle se configure dans la stratégie de conformité (§8.2).

CONSEIL **résultat attendu.** Les appareils inscrits dans Intune apparaissent dans security.microsoft.com → Appareils. Le délai exact est à relever lors de la première inscription.

Partie 1 : Inscription des appareils Windows

1.1 Windows Autopilot (appareils neufs)

N°	Étape	Action
C1	Hachages matériels	Identifiant unique de chaque poste. À demander au revendeur à l'achat, ou à extraire avec PowerShell (deux commandes séparées, exécutées sur le poste à enregistrer).
C2	Commande 1	`Install-Script -Name Get-WindowsAutoPilotInfo -Force`
C3	Commande 2	`Get-WindowsAutoPilotInfo -OutputFile C:\hachage.csv`
1	Importer	intune.microsoft.com → Appareils → Intégration de l'appareil → Inscription → onglet Windows → section « Windows Autopilot » → Appareils → Importer → sélectionner le CSV. Le bouton Synchroniser de la même barre d'outils force la synchronisation avec le service Autopilot.
2	Vérifier	Dans la liste « Appareils Windows AutoPilot », contrôler les colonnes Numéro de série, Fabricant, Modèle, Étiquette de groupe et État du profil. Cliquer sur Actualiser jusqu'à l'apparition de l'appareil importé.
3	Profil	Retour à Inscription → onglet Windows → section « Windows Autopilot » → Profils de déploiement → Créez un profil → PC Windows.
4	Informations de base	Nom : sans le caractère « - » (le portail le refuse), par exemple « PC Joint à Microsoft Entra ». Laisser « Convertir tous les appareils ciblés en Autopilot » sur Non → Suivant.
5	OOBE	Onglet « OOBE (Out-Of-Box Experience) » : Mode de déploiement = Géré par l'utilisateur ; Rejoindre Microsoft Entra ID en tant que = Joint à Microsoft Entra ; Termes du contrat de licence logiciel Microsoft et Paramètres de confidentialité = Masquer ; Masquer les options de changement de compte = Masquer ; Type de compte d'utilisateur = Standard ; Autoriser le déploiement préconfiguré = Non. [nLPD art. 8]
6	Affecter	Onglet « Attributions » → affecter le profil au groupe `GRP-Appareils-Windows` (Partie 0) → Suivant → « Vérifier + créer » → Créer.
7	Test	Test sur un poste neuf : voir test T1 (Partie 13).

INFO **valeurs par défaut du portail.** Dans l'onglet OOBE, le type de compte d'utilisateur est proposé avec le choix Administrateur ou Standard : choisir Standard pour que l'utilisateur ne soit pas administrateur local du poste. Le portail propose aussi « Appliquer le modèle de nom d'appareil » (Non par défaut) et « Configurer automatiquement le clavier ».

INFO **Préparation de l'appareil Windows Autopilot.** La même page Inscription → Windows propose la section « Préparation de l'appareil Windows Autopilot » (Politiques de préparation des appareils), qui est le mode moderne sans import de hachage. Il n'est pas détaillé dans ce guide ; à évaluer séparément.

INFO **À CONFIRMER : étapes non vérifiées.** Le sélecteur de fichier de l'import, les libellés exacts de l'onglet « Attributions » et la correspondance du test avec T1 ne sont pas encore validés sur le portail.

CONSEIL **résultat attendu.** Le poste démarre, l'utilisateur saisit son compte M365, le poste rejoint Entra ID et s'inscrit dans Intune. Les politiques s'appliquent après quelques minutes à quelques dizaines de minutes.

INFO **lien avec Token Protection (CA-04).** Les appareils Autopilot en mode self-deploying et les appareils inscrits en masse (bulk enrollment) ne sont pas supportés par Token Protection : voir Partie 12.

1.2 Inscription manuelle (appareils existants)

N°	Étape	Action
1	Ouvrir	intune.microsoft.com → Appareils → Intégration de l'appareil → Inscription → onglet Windows → section « Options d'inscription » → Inscription automatique (ouvre la page « Microsoft Intune »).
2	Étendue MDM	Champ « Étendue de l'utilisateur Gestion des données de référence » (traduction française du portail pour MDM) : choisir Tout pour inscrire tous les utilisateurs, ou Partiel → « groupe(s) sélectionné(s) » pour limiter à un groupe de pilotage. Les choix proposés sont Aucun, Partiel, Tout.
3	URL	Laisser les trois URL par défaut (conditions d'utilisation, découverte, conformité). Le lien « Restaurer les URL Gestion des données de référence par défaut » les rétablit en cas de modification.
4	Enregistrer	Bouton Enregistrer en bas de page (grisé tant que rien n'est modifié).
5	Sur le poste	Paramètres → Comptes → Accès professionnel ou scolaire → Connexion → compte M365.
6	Vérification	intune.microsoft.com → Appareils → Tous les appareils : le poste apparaît après la synchronisation.

INFO **ne pas modifier la section WIP.** La même page contient « Étendue de l'utilisateur Protection des informations Windows (WIP) » avec ses URL TEC. Cette section n'est pas utilisée dans ce guide : la laisser telle quelle.

INFO **option de désactivation.** Le commutateur « Désactivez l'inscription MDM lors de l'ajout d'un compte professionnel ou scolaire sur Windows » doit rester sur Non (valeur relevée sur le tenant de validation), sinon l'ajout d'un compte M365 sur le poste ne l'inscrit plus dans Intune.

INFO **À CONFIRMER : étapes non vérifiées.** Le délai d'apparition du poste dans « Tous les appareils » et le chemin « Paramètres → Comptes → Accès professionnel ou scolaire » sur le poste n'ont pas été testés.

1.3 Jonction hybride (environnements AD sur site)

N°	Étape	Action
C1	Cas d'usage	Client avec Active Directory et Entra Connect. Les postes joints au domaine sont aussi joints hybrides à Entra ID et inscrits dans Intune par GPO.
1	GPO	Inscription MDM automatique par GPO (Configuration ordinateur → Modèles d'administration → Composants Windows → MDM). Libellé exact de la stratégie à relever sur un contrôleur de domaine.
2	Vérification	entra.microsoft.com → Appareils → Tous les appareils. Faire défiler vers la droite jusqu'aux colonnes « Type de jointure », « Propriétaire » et « GPM » (traduction du portail pour MDM). Le type de jointure d'un poste hybride commence par « Microsoft Entra hy… » ; les autres valeurs vues commencent par « Microsoft Entra joi… » (joint) et « Microsoft Entra reg… » (inscrit).
3	Contrôle Intune	Colonne « GPM » : le nom de l'application de gestion (Microsoft Intune) doit apparaître pour le poste. Valeur « Aucun » = poste non inscrit dans Intune.

ATTENTION Entra Connect doit synchroniser les objets ordinateurs avant toute tentative de jonction hybride.

Partie 2 : Inscription des appareils mobiles

2.1 iOS et iPadOS

N°	Étape	Action
C1	Certificat APNs	Certificat Apple requis, renouvelé chaque année. Documenter la date d'expiration dans le registre du client : un APNs expiré bloque la gestion de tous les appareils iOS.
1	Ouvrir	intune.microsoft.com → Appareils → Intégration de l'appareil → Inscription → onglet Apple → section « Conditions préalables » → Certificat Push MDM Apple (ouvre la page « Configurer le certificat Push MDM »).
2	Autorisation	Étape 1 de la page : cocher « J'accepte. » (autorisation donnée à Microsoft d'envoyer des informations sur l'utilisateur et l'appareil à Apple). [nLPD art. 8]
3	CSR	Étape 2 : lien « Télécharger votre CSR » (demande de signature de certificat Intune).
4	Certificat Apple	Étape 3 : lien « Créez votre certificat Push MDM » (ouvre le portail Apple). Utiliser un identifiant Apple d'entreprise dédié, jamais un compte personnel.
5	ID Apple	Étape 4 : saisir l'ID Apple utilisé (champ « ID Apple »).
6	Charger	Étape 5 : « Certificat Push MDM Apple » → « Sélectionner un fichier » → bouton Charger.
7	Contrôle	Dans le bloc « Bases » de la même page : État, Dernière mise à jour, ID Apple, Numéro de série, Nombre de jours avant expiration, Expiration, ID de sujet. Relever la date d'Expiration dans le registre du client.
8	Types d'inscription	Retour à l'onglet Apple → section « Options d'inscription » → Types d'inscription. Cette entrée reste grisée tant que le certificat n'est pas installé.
9	Inviter	Envoyer les instructions d'inscription aux utilisateurs.
10	Vérification	Intune → Appareils → Par plateforme → Apple mobile, puis contrôle d'appartenance à `GRP-Appareils-iOS`.

INFO **autres méthodes de l'onglet Apple.** Section « Méthodes d'inscription en bloc » : Configurateur Apple et Jetons du programme d'inscription (Apple Business Manager et Apple School Manager). Section « Options d'inscription » : Types d'inscription, Restrictions de la plate-forme de l'appareil, Restrictions du nombre limite d'appareils. Non détaillées dans ce guide.

INFO **À CONFIRMER : iOS non testable sur le tenant de validation.** Le certificat y est à l'état « Non installé » et aucun appareil iOS n'est inscrit : les options de « Types d'inscription » (User Enrollment, Device Enrollment), le libellé des instructions aux utilisateurs et la règle de groupe `GRP-Appareils-iOS` restent à valider avec un certificat APNs réel.

INFO **BYOD et nLPD.** En User Enrollment, Intune n'accède pas aux données personnelles de l'appareil. Communiquez ce point aux collaborateurs et documentez le traitement dans la politique d'utilisation des appareils personnels.

2.2 Android

N°	Étape	Action
C1	Google Play géré	Lier Intune à un compte Google Play géré dédié à l'entreprise, jamais un compte Gmail personnel.
1	Ouvrir	intune.microsoft.com → Appareils → Intégration de l'appareil → Inscription → onglet Android → section « Android Enterprise » → « Conditions préalables » → Google Play géré.
2	Autorisation	Étape 1 de la page : cocher « J'accepte. » (autorisation donnée à Microsoft d'envoyer des informations sur l'utilisateur et l'appareil à Google). [nLPD art. 8]
3	Connexion Google	Étape 2 : bouton « Se connecter à Google maintenant » avec le compte Google d'entreprise dédié.
4	Contrôle	Dans le bloc « Bases » : État = Installation (coche verte), Compte lié, Organisation, Date d'inscription.
5	Profil	Onglet Android → section « Profils d'inscription » : choisir « Appareils personnels avec un profil professionnel » pour le BYOD. Les autres entrées sont « Appareils dédiés appartenant à l'entreprise », « Appareils utilisateur entièrement gérés appartenant à l'entreprise » et « Appareils appartenant à l'entreprise avec profil professionnel ».
6	Inviter	Envoyer les instructions d'inscription aux utilisateurs.
7	Vérification	Intune → Appareils → Par plateforme → Android, puis contrôle d'appartenance à `GRP-Appareils-Android`.

INFO **Inscription Zero-Touch.** La section « Méthodes d'inscription en bloc » propose « Inscription Zero-Touch » et « Inscription Samsung Knox Mobile ». Le portail indique qu'à compter de juillet 2026 les administrateurs doivent disposer de l'autorisation RBAC « Inscription sans contact gérée » pour gérer ZTE. Non détaillées dans ce guide.

INFO **À CONFIRMER : inscription d'un appareil.** Le lien Google Play géré est actif sur le tenant de validation (compte lié, état Installation). Les écrans de création d'un profil d'inscription et l'inscription d'un appareil réel n'ont pas été parcourus.

Partie 3 : Chiffrement et contrôle des périphériques

nLPD art. 8 al. 1 : protection des données au repos et prévention de l'exfiltration physique. Un poste perdu ou volé sans chiffrement expose toutes les données personnelles qu'il contient. Un support USB non contrôlé est un vecteur d'exfiltration simple.

3.1 BitLocker : chiffrement des postes Windows

N°	Étape	Action
C1	Objectif	Chiffrer le disque entier. La clé de récupération est stockée dans Entra ID via Intune.
C2	Algorithme	AES 256 bits : choix de durcissement retenu par le MVC. AES 128 bits reste une configuration reconnue par Microsoft : ne pas présenter AES-256 comme une obligation.
C3	Étendue	Chiffrement intégral du disque pour les postes qui contiennent déjà des données. Chiffrement de l'espace utilisé seulement acceptable sur un poste neuf, vide.
1	Chemin	intune.microsoft.com → Sécurité du point de terminaison → Gérer → Chiffrement de disques → bouton « Créer Azure Policy » (libellé du portail pour créer une stratégie) → Plateforme : Windows → Profil : BitLocker → Créer. Le second profil proposé, « Chiffrement des données personnelles », n'est pas utilisé ici.
2	Informations de base	Onglet « Basics » : Nom (par exemple `BitLocker-Windows-[Nom du client]`) et Description → Suivant. Les onglets de l'assistant restent en anglais : Basics, Configuration settings, Scope tags, Assignments, Review + create.
3	Appareils	Onglet « Configuration settings », catégorie « BitLocker » : « Exiger le chiffrement des appareils » → Activé ; « Autoriser l'avertissement pour un autre chiffrement de disque » → Désactivé pour un chiffrement silencieux (ce choix fait apparaître le paramètre « Autoriser le chiffrement utilisateur standard », Désactivé par défaut : à examiner si les utilisateurs ne sont pas administrateurs locaux) ; « Configurer la rotation du mot de passe de récupération » → à choisir.
4	Algorithme	Catégorie « BitLocker Drive Encryption » : « Choose drive encryption method and cipher strength (Windows 10 [Version 1511] and later) » → Enabled. Trois listes apparaissent : lecteurs du système d'exploitation (défaut XTS AES 128 bits), lecteurs de données fixes (défaut XTS AES 128 bits), lecteurs de données amovibles (défaut AES-CBC 128 bits). Choix proposés : AES-CBC 128 bits, AES-CBC 256 bits, XTS AES 128 bits, XTS AES 256 bits. Retenir XTS AES 256 bits pour le système et les disques fixes (voir C2).
5	Démarrage	Catégorie « Operating System Drives » : « Require additional authentication at startup » → Enabled. Sous-options : « Allow BitLocker without a compatible TPM », « Configurer la clé de démarrage de module de plateforme sécurisée », « Configurer le code PIN de démarrage de module de plateforme sécurisée », « Configurer le code PIN et la clé de démarrage », « Configurer le démarrage du module de plateforme sécurisée ». Choix TPM seul ou TPM + PIN : voir Annexe E. Paramètres voisins : « Configure minimum PIN length for startup », « Allow enhanced PINs for startup », « Disallow standard users from changing the PIN or password ».

N°	Étape	Action
6	Récupération	Même catégorie : « Choose how BitLocker-protected operating system drives can be recovered » → Enabled. Valeurs proposées par défaut : « Allow data recovery agent » = True, mot de passe de récupération à 48 chiffres autorisé, clé de récupération 256 bits autorisée, « Save BitLocker recovery information to AD DS for operating system drives » = True. Dans un environnement 100 % cloud, le stockage dans AD DS ne s'applique pas : voir la vérification de l'étape 8. [nLPD art. 8]
7	Affecter	Onglet « Assignments » → groupe `GRP-Appareils-Windows` → onglets « Scope tags » (laisser par défaut) puis « Review + create » → Create.
8	Vérification	Sur le poste : `Get-BitLockerVolume` → état « FullyEncrypted », protection « On ». Dans le portail : entra.microsoft.com → Appareils → Tous les appareils → [appareil] → « Clés BitLocker » : la clé de récupération du poste doit apparaître après le chiffrement. La page globale Appareils → « Clés BitLocker » n'affiche rien sans identifiant de clé complet (32 caractères) : passer par la fiche de l'appareil.

INFO **lecture des clés par les utilisateurs.** Dans Entra → Appareils → Paramètres de l'appareil, section « Autres paramètres », le commutateur « Empêcher les utilisateurs de récupérer les clés BitLocker des appareils qui leur appartiennent » est sur Non sur le tenant de validation. Le mettre sur Oui limite la lecture des clés aux administrateurs.

CONSEIL **sauvegarde de la clé dans Entra ID.** Aucun des paramètres de la stratégie n'est libellé « Entra ID », mais la clé de récupération apparaît bien sur la fiche de l'appareil dans Entra ID une fois le chiffrement terminé (étape 8, vérifié sur un poste Autopilot). Les noms de ces catégories et paramètres sont affichés en anglais par le portail (traduction partielle).

ATTENTION **chiffrement silencieux qui ne démarre pas.** Le chiffrement silencieux exige un TPM (un TPM virtuel suffit sur une machine virtuelle) et aucun support de démarrage amovible connecté (image ISO ou clé USB). Sinon l'événement 853 apparaît dans le journal « Microsoft-Windows-BitLocker/BitLocker Management » (code d'erreur -2144272336). Éjecter le support, redémarrer, relancer la synchronisation Intune. Un Secure Boot désactivé ne génère qu'un avertissement et n'empêche pas le chiffrement.

3.2 BitLocker To Go : clés USB autorisées

N°	Étape	Action
C1	Objectif	Si des clés USB sont autorisées, leur contenu doit être chiffré : une clé perdue est illisible sans le mot de passe.
1	Chemin	Dans le profil BitLocker de la §3.1 (onglet « Configuration settings »), catégorie « Removable Data Drives ». Il n'existe pas de catégorie nommée « BitLocker To Go » dans le portail.
2	Paramètres	« Control use of BitLocker on removable drives » → Enabled ; « Deny write access to removable drives not protected by BitLocker » → Enabled (une clé non chiffrée devient en lecture seule).
3	Algorithme	Catégorie « BitLocker Drive Encryption » : la liste des lecteurs de données amovibles (défaut AES-CBC 128 bits) se règle avec le paramètre de l'étape 4 de la §3.1.
4	Test	Test sur une clé USB vierge : le message affiché et le comportement exact restent à relever.

ATTENTION **alternative.** Pour les PME à données très sensibles (médical, avocats), interdire totalement les clés USB (§3.3) est plus simple et plus sûr.

3.3 Device Control : blocage des USB non autorisées

N°	Étape	Action
C1	Objectif	Bloquer les supports USB non autorisés pour prévenir l'exfiltration de données personnelles. `[nLPD art. 8]`
C2	Niveaux possibles	Bloquer tous les supports de stockage USB. Lecture seule. Autoriser uniquement les clés chiffrées BitLocker To Go. Autoriser par liste blanche (identifiant fabricant et produit).
1	Chemin	intune.microsoft.com → Sécurité du point de terminaison → Gérer → Réduction de la surface d'attaque → onglet Stratégies → « Créer Azure Policy » → Plateforme : Windows → Profil : Contrôle de l'appareil → Créer. Les autres profils proposés sont : Isolation de l'application et du navigateur (ConfigMgr), Règles de réduction de la surface d'attaque, Protection Exploit, Contrôle d'application.
2	Informations de base	Onglet « Basics » : Nom (par exemple `DeviceControl-Windows-[Nom du client]`) → Suivant.
3	Activer	Onglet « Configuration settings », catégorie « Defender » : « Contrôle d'appareil activé » → Activé. Autres paramètres de la catégorie : « Autoriser l'analyse complète des lecteurs amovibles », « Application par défaut » (choix : Autoriser l'application par défaut (Par défaut) ou Refuser l'application par défaut), « Configuration des appareils sécurisés ».
4	Règles	Catégorie « Contrôle de l'appareil » : tableau Nom / Appareils inclus / Appareils exclus / Accès, bouton Ajouter. Les règles s'appuient sur les « Paramètres réutilisables » (onglet de la page Réduction de la surface d'attaque, à côté de Stratégies). Choisir le niveau selon le profil de risque du client (C2).
5	Exceptions	Exceptions éventuelles pour `GRP-USB-Autorises` : colonne « Appareils exclus » d'une règle.
6	Affecter	Onglet « Assignments » → `GRP-Appareils-Windows` → « Review + create » → Create.

INFO **deux familles de paramètres.** Le portail précise que les catégories « Defender » et « Contrôle de l'appareil » configurent le contrôle des appareils de Microsoft Defender for Endpoint (MDE), et que toutes les autres catégories (Device Installation Restrictions, Removable Storage Access, Protection DMA, Stockage, Connectivité, Bluetooth, Système) configurent le contrôle natif de Windows. Les appareils concernés par les règles MDE doivent être intégrés à MDE (§4.1). La catégorie « Removable Storage Access » ne contient que des paramètres « WPD Devices: Deny read/write access » (appareils portables).

INFO **À CONFIRMER : niveaux de blocage.** Les groupes de supports réutilisables, les valeurs exactes de la colonne « Accès » et le paramètre natif qui bloque les disques USB de stockage de masse (catégorie « Stockage » non ouverte) ne sont pas encore validés.

CONSEIL **test.** Insérer une clé USB non autorisée : l'accès est refusé. Le message exact affiché est à relever lors de la validation terrain.

Partie 4 : Politiques Endpoint Security

> **ATTENTION** toute la configuration de cette partie se fait dans intune.microsoft.com → Sécurité du point de terminaison, pas dans le portail Defender XDR. Toutes les politiques de cette partie ciblent `GRP-Appareils-Windows`.

4.1 Politique EDR (détection et réponse des points de terminaison)

N°	Étape	Action
C1	Objectif	Surveillance comportementale des postes, isolation réseau des postes compromis, collecte de données d'investigation. À configurer avant l'antivirus. Nécessite le connecteur de la §0.3.
1	Contrôle du connecteur	intune.microsoft.com → Sécurité du point de terminaison → Gérer → Détection et réponse des points de terminaison. Onglet « Résumé » : « État du connecteur Defender for endpoint » doit afficher « Le connecteur Defender for endpoint est activé ». Le bloc « Appareils Windows intégrés à Defender for Endpoint » compte les postes intégrés / non intégrés.
2	Politique par défaut	Même page, section « Stratégies de détection et de réponse des points de terminaison (PEPT) » : une politique `Default EDR policy for all devices` (description : « Default EDR policy for targeting all tenants devices, created by MDE ») peut déjà exister, créée par Defender. Ouvrir la politique : son seul paramètre est « Type de package de configuration du client Microsoft Defender for Endpoint » = « Auto à partir du connecteur », affectée à « Tous les appareils », sans filtre ni exclusion. Si elle existe, **ne pas créer de seconde politique EDR** (doublon) : passer à l'étape 6.
3	Créer (si absente)	Même section → « Créer une stratégie » → Plateforme : Windows → Profil : Détection et réponse des points de terminaison → Créer. Autres plateformes proposées : Linux, MacOS, Windows (ConfigMgr).
4	Informations de base	Onglet « Basics » : Nom (par exemple `EDR-Windows-[Nom du client]`) → Suivant.
5	Type de package	Onglet « Configuration settings », catégorie « Microsoft Defender for Endpoint » : « Type de package de configuration du client Microsoft Defender for Endpoint » → « Auto à partir du connecteur » (recommandé). Les autres choix sont « Intégrer » et « Annuler l'intégration ». Même catégorie : « Partage d'exemples » → Tout (par défaut) ou Aucun ; le paramètre « [Déconseillé] Fréquence des rapports de télémétrie » est déconseillé : le laisser non configuré. Onglet « Assignments » → `GRP-Appareils-Windows` → « Review + create » → Create.
6	Contrôle de la politique	Ouvrir la politique → « Afficher le rapport » : un enregistrement par appareil et par compte (utilisateur et compte du système), avec l'état « Réussite ». Les compteurs en tête de page (Réussite, Erreur, Conflit, Non applicable, En cours) doivent afficher 0 erreur et 0 conflit.
7	Vérification dans Defender XDR	security.microsoft.com → Ressources → Appareils (accès direct : `security.microsoft.com/machines`). Le poste figure dans « Inventaire des appareils ». Ouvrir sa fiche → « Afficher Détails de l'ordinateur virtuel » (pour une machine virtuelle) ou « Afficher À propos de cette ressource » : « État de l'intégration » doit afficher « Intégré », avec « Dernière détection » récente. Section « Gestion des appareils » ou « Configuration et gestion » : « Géré par » = Intune. Sur le poste, `Get-Service sense` doit afficher « Running ».

INFO **relevé du 8 novembre 2026** sur le tenant de validation : un poste Windows 11 inscrit à Intune (`[nom du poste]`) figurait dans l'inventaire Defender, « Intégré », « Géré par : Intune », service `sense` en cours d'exécution. Le chemin et les libellés de l'étape 7 sont validés.

ATTENTION **serveurs et contrôleurs de domaine.** La politique par défaut vise « Tous les appareils ». Selon la documentation Microsoft sur la gestion des paramètres de sécurité MDE, une politique déployée sur « Tous les appareils » inscrit automatiquement tout appareil entrant dans le périmètre configuré, et la configuration des contrôleurs de domaine exige que celle des serveurs Windows soit d'abord activée. Ne pas activer cette gestion sur un contrôleur de domaine sans test préalable : une mauvaise configuration peut nuire à la sécurité et à la continuité de service.

INFO **À CONFIRMER : licence serveur.** Un serveur (par exemple un contrôleur de domaine) peut être onboardé dans Defender for Endpoint. La page Licences (security.microsoft.com → Paramètres → Points de terminaison → Licences) liste les abonnements détectés. L'onboarding des serveurs relève d'une licence distincte de Defender for Business : la référence exacte reste à vérifier dans la documentation Microsoft avant de la recommander au client.

INFO **À CONFIRMER : compteur du résumé.** La page « Détection et réponse des points de terminaison », onglet « Résumé », affichait « Appareils Windows intégrés à Defender for Endpoint » à 0 (Intégré 0, Non intégré 0, Total 0) alors que le rapport de la politique comptait des appareils en « Réussite » et que l'inventaire Defender les montrait « Intégré ». L'écart n'est pas expliqué.

4.2 Antivirus nouvelle génération

N°	Étape	Action
C1	Paramètres clés (propositions)	Surveillance en temps réel : autorisée. Protection cloud : autorisée. Niveau de blocage du cloud : Élevé. Délai d'expiration étendu pour le cloud : valeur entre 0 et 50 (le portail refuse toute autre valeur). Envoi d'exemples : « Envoyer automatiquement les exemples sécurisés ». Ce sont des valeurs de durcissement proposées par le MVC, pas des valeurs imposées par le portail.
1	Chemin	intune.microsoft.com → Sécurité du point de terminaison → Gérer → Antivirus → « Créer Azure Policy » → Plateforme : Windows → Profil : Microsoft Defender Antivirus → Créer. Les autres profils proposés sont : Contrôles de mise à jour Defender, Microsoft Defender AI agent runtime protection, Exclusions de Microsoft Defender Antivirus, Expérience de sécurité Windows.
2	Informations de base	Onglet « Basics » : Nom (par exemple `Antivirus-Windows-[Nom du client]`) → Suivant.
3	Paramètres	Onglet « Configuration settings », catégorie « Defender » (libellés en français, avec un champ Rechercher en haut de la liste) : « Autoriser la surveillance en temps réel », « Autoriser la protection cloud », « Niveau de blocage du cloud » (choix : État par défaut (Par défaut), Élevé, Plus élevé, Tolérance zéro), « Délai d'expiration étendu pour le cloud » (commutateur puis valeur entière de 0 à 50), « Consentement concernant l'envoi d'exemples » (choix : Toujours demander, Envoyer automatiquement les exemples sécurisés (Par défaut), Ne jamais envoyer, Envoyer automatiquement tous les exemples). [nLPD art. 8]
4	Affecter	Onglet « Assignments » → `GRP-Appareils-Windows` → « Review + create » → Create.

INFO **exemples envoyés à Microsoft.** « Envoyer automatiquement tous les exemples » peut transmettre des fichiers entiers à Microsoft, y compris des documents qui contiennent des données personnelles. Le choix « exemples sécurisés » (valeur par défaut) limite cet envoi. À documenter dans le registre des traitements du client.

CONSEIL **test EICAR.** Télécharger le fichier de test EICAR sur un poste géré : il doit être bloqué, et une alerte doit apparaître dans Defender XDR. Le délai d'apparition de l'alerte est à relever lors de la validation terrain.

4.3 Tamper Protection

N°	Étape	Action
C1	Objectif	Empêche une application ou un script de désactiver Defender. Les ransomwares tentent souvent de désactiver l'antivirus avant d'agir.
1	Chemin	Le paramètre ne se trouve pas dans le profil « Microsoft Defender Antivirus » mais dans le profil « Expérience de sécurité Windows » : intune.microsoft.com → Sécurité du point de terminaison → Gérer → Antivirus → « Créer Azure Policy » → Plateforme : Windows → Profil : Expérience de sécurité Windows → Créer.
2	Paramètre	Onglet « Configuration settings », catégorie « Defender » : « Protection contre les falsifications (Appareil) » → activer. Affecter à `GRP-Appareils-Windows`.
3	Vérification	security.microsoft.com → Paramètres → Points de terminaison → Général → Fonctionnalités facultatives → « Protection contre les falsifications » : le commutateur doit être sur Activé.

ATTENTION en cas de besoin de diagnostic, utilisez le mode de dépannage (§6.2). Ne désactivez jamais la Tamper Protection globalement.

4.4 Pare-feu

N°	Étape	Action
C1	Profils	Trois profils à activer : Domaine, Privé, Public.
1	Chemin	intune.microsoft.com → Sécurité du point de terminaison → Gérer → Pare-feu → « Créer Azure Policy » → Plateforme : Windows → Profil : Pare-feu Windows → Créer. Les autres profils Windows proposés sont « Règles de pare-feu Windows » et « Règles de pare-feu Windows Hyper-V ».
2	Informations de base	Onglet « Basics » : Nom (par exemple `Pare-feu-Windows-[Nom du client]`) → Suivant.
3	Profils réseau	Onglet « Configuration settings », catégorie « Pare-feu » : « Activer le pare-feu sur un réseau avec domaine », « Activer le pare-feu sur un réseau privé » et « Activer le pare-feu sur un réseau public » → activer les trois.
4	Règles	Ajouter des règles personnalisées seulement si une application métier l'exige : profil « Règles de pare-feu Windows », créé séparément.
5	Affecter	Onglet « Assignments » → `GRP-Appareils-Windows` → « Review + create » → Create.
6	Vérification	Page Pare-feu, onglet « Résumé » : le bloc « Appareils avec pare-feu désactivé » doit rester à zéro.

INFO **libellés.** Le profil s'appelle « Pare-feu Windows » dans le portail (et non « Pare-feu Windows Defender »). La liste de paramètres contient aussi une section « Audit » : non utilisée ici.

4.5 Règles ASR (réduction de la surface d'attaque)

N°	Étape	Action
C1	Objectif	Bloquer les comportements utilisés par les malwares : macros Office, scripts obfusqués, vol d'identifiants depuis LSASS, exécution depuis les dossiers temporaires.
C2	Audit, puis Avertir, puis Blocage	14 jours en mode Audit pour repérer les faux positifs (anciens logiciels comptables, ERP). Passer ensuite en mode Avertir si disponible pour la règle, puis en Blocage, règle par règle.
C3	Règles prioritaires (libellés du portail)	« Bloquer le contenu exécutable du client de messagerie et de la messagerie web ». « Empêcher le vol des informations d'identification dans le sous-système de l'autorité de sécurité locale Windows ». « Bloquer les créations de processus provenant de commandes PSExec et WMI ». « Bloquer les appels d'API Win32 à partir des macros Office ». « Empêcher les fichiers exécutables de s'exécuter, sauf s'ils répondent à des critères de prévalence » (fin du libellé tronquée à l'écran). « Bloquer l'abus de pilotes signés vulnérables exploités (appareil) ». « Empêcher toutes les applications Office de créer des processus enfants ». Aucune règle relative aux « dossiers temporaires » n'a été trouvée sous ce libellé : la liste complète reste à relire.
C4	Modes	Chaque règle propose : Non configurée, Désactivé (Par défaut), Bloquer, Audit, Avertir.
1	Chemin	intune.microsoft.com → Sécurité du point de terminaison → Gérer → Réduction de la surface d'attaque → onglet Stratégies → « Créer Azure Policy » → Plateforme : Windows → Profil : Règles de réduction de la surface d'attaque → Créer.
2	Informations de base	Onglet « Basics » : Nom (par exemple `ASR-Windows-[Nom du client]`) → Suivant.
3	Audit	Onglet « Configuration settings », section « Règles de réduction de la surface d'attaque » : régler les règles prioritaires sur Audit. Le champ Rechercher de l'assistant permet de retrouver une règle par mot-clé (PSExec, macro).
4	Affecter	Onglet « Assignments » → `GRP-Appareils-Windows` → « Review + create » → Create.
5	Rapport	Après 14 jours : security.microsoft.com → Rapports → onglet Points de terminaison → Règles de réduction de la surface d'attaque (accès direct : security.microsoft.com/asr). Onglets du rapport : Detections, Configuration, Add exclusions (libellés français du portail à relever). Chemin et onglets tirés de la documentation Microsoft, non vérifiés sur le tenant.
6	Exclusions	Onglet « Add exclusions » du rapport : sélectionner les fichiers, lire le volet « Summary & expected impact », puis « Add exclusions » (ouvre Intune) ou « Get selected exclusion paths » (CSV). Les exclusions portent sur des fichiers ou dossiers et valent pour toutes les règles ASR : un fichier exclu s'exécute sans événement ni rapport. En cas de doute sur un faux positif, repasser la règle en Audit et investiguer d'abord.
7	Blocage	Passer les règles de Audit à Bloquer (ou Avertir), une règle à la fois, et vérifier après chaque passage.

INFO **À CONFIRMER : suite du déploiement ASR.** Le rapport ASR, les exclusions et le passage en blocage n'ont pas été parcourus : ils dépendent de postes qui remontent des événements.

4.6 Network Protection

N°	Étape	Action
C1	Objectif	Étend la protection SmartScreen à toutes les connexions réseau du poste, y compris les autres navigateurs et applications.
1	Chemin	Le paramètre se trouve dans le profil Antivirus, pas dans la Réduction de la surface d'attaque : profil « Microsoft Defender Antivirus » (§4.2) → onglet « Configuration settings », catégorie « Defender » → « Activer la protection réseau ».
2	Valeur	Choix : Désactivé (Par défaut), Activé (mode de blocage), Activé (mode audit). Mode audit pendant 7 jours, puis mode de blocage.
3	Complément	Le paramètre voisin « Autoriser le niveau inférieur de Protection réseau » reste non configuré.

4.7 Windows LAPS : mot de passe administrateur local

N°	Étape	Action
C1	Objectif	Windows LAPS génère et renouvelle automatiquement un mot de passe unique par poste pour le compte administrateur local. Sans LAPS, un même mot de passe local sur tous les postes permet le mouvement latéral après la compromission d'un seul. `[nLPD art. 8]`
C2	Prérequis tenant	Le tenant doit autoriser LAPS : entra.microsoft.com → Appareils → Gérer → Paramètres de l'appareil → section « Paramètres de l'administrateur local » → « Activer la solution de mot de passe d'administrateur local (LAPS) Microsoft Entra » → Oui → Enregistrer.
C3	Durée et complexité	Rotation recommandée : 30 jours. Complexité : 14 caractères minimum, majuscules, minuscules, chiffres et caractères spéciaux.
1	Chemin	intune.microsoft.com → Sécurité du point de terminaison → Gérer → Protection de compte → « Créer Azure Policy » → Plateforme : Windows → Profil : Solution de mot de passe d'administrateur local (Windows LAPS) → Créer. Les autres profils sont « Protection de compte » et « Modifier l'appartenance au groupe de l'utilisateur ».
2	Informations de base	Onglet « Basics » : Nom (par exemple `LAPS-Windows-[Nom du client]`) → Suivant.
3	Paramètres	Onglet « Configuration settings », catégorie « LAPS » : « Répertoire de sauvegarde » → « Sauvegarder le mot de passe sur Microsoft Entra ID uniquement » (autres choix : Désactivé ; Active Directory uniquement). Un champ « Jours d'âge du mot de passe » apparaît alors, affiché à 30. « Complexité des mots de passe » : choisir « Lettres majuscules + lettres minuscules + chiffres + caractères spéciaux » (libellé tronqué à l'écran). « Longueur du mot de passe » : 14. Autres paramètres, laissés « Non configuré » ici : « Nom du compte d'administrateur », « Actions post-authentification », « Délai après la réinitialisation de l'authentification ». « Gestion automatique des comptes activée » : voir étape 4.

N°	Étape	Action
4	Compte géré	Sans réglage, Windows LAPS cible le compte « Administrateur » intégré, désactivé par défaut sous Windows 11 : le mot de passe est généré et stocké, mais personne ne peut se connecter (événement 10067 dans le journal « Microsoft-Windows-LAPS/Operational »). Microsoft recommande de laisser le compte intégré désactivé et de gérer un compte personnalisé. Même catégorie « LAPS » : « Gestion automatique des comptes activée » → « Le compte cible sera géré automatiquement ». Quatre sous-paramètres apparaissent : « Cible de gestion automatique des comptes » → « Gérer un nouveau compte d'administrateur personnalisé (Par défaut) » ; « Nom ou préfixe de gestion automatique des comptes » → activer, puis saisir le nom du compte (par exemple `[Nom du compte local]`) ; « Activer le compte de gestion automatique des comptes » → « Le compte cible sera activé » (par défaut : désactivé) ; « Nom aléatoire de la gestion automatique des comptes » → laisser « Le nom du compte cible n'utilise pas de suffixe numérique aléatoire. (Par défaut) ». Ce mode exige Windows 11 24H2 ou plus récent (ou Windows Server 2025). Sur une version antérieure : créer le compte à l'avance et le nommer dans « Nom du compte d'administrateur ».
5	Affecter	Onglet « Assignments » → `GRP-Appareils-Windows` → « Review + create » → Create.
6	Qui peut lire	Selon la documentation Microsoft, seuls deux rôles intégrés lisent le mot de passe : Administrateur d'appareils cloud (Cloud Device Administrator) et Administrateur Intune. Les rôles Administrateur du support technique, Administrateur de la sécurité et Lecteur de sécurité ne voient que les métadonnées (nom de l'appareil, dernière et prochaine rotation). Pour un accès plus fin : rôle personnalisé avec l'autorisation `microsoft.directory/deviceLocalCredentials/password/read` (Entra ID P1 ou P2 requis), ou unité administrative contenant les appareils avec le rôle Administrateur d'appareils cloud limité à cette unité. Les stratégies d'accès conditionnel ne peuvent cibler que les rôles intégrés. Libellés français des rôles à relever dans le portail.
7	Consulter	entra.microsoft.com → Appareils → Gérer → Récupération du mot de passe d'administrateur local, ou fiche de l'appareil. Le volet « Mot de passe d'administrateur local » affiche : « Nom du compte », « ID de sécurité », « Mot de passe d'administrateur local » (masqué, avec boutons d'affichage et de copie), « Dernier renouvellement automatique du mot de passe » et « Prochain renouvellement automatique du mot de passe ».
8	Connexion locale	Écran de connexion Windows → « Autre utilisateur » → saisir `.\[Nom du compte local]` et le mot de passe lu. Sans le préfixe `.\`, Windows interprète le nom comme un compte Entra ID et refuse la connexion.
9	Traçabilité	Chaque consultation est journalisée dans les journaux d'audit Entra ID (entra.microsoft.com → Appareils → Activité → Journaux d'audit) : revoir ces journaux à fréquence définie et documenter la revue dans le registre de sécurité. Colonnes : Date, Service, Catégorie, Activité, Statut, Motif d'état, Cible(s), Initié par (acteur). Filtre « Activité » (libellés anglais relevés dans le portail, service « Device Registration Service ») : « Recover device local administrator password » pour les lectures, avec le compte de l'administrateur dans « Initié par (acteur) » ; « Update device local administrator password » pour les générations et rotations, sans acteur humain affiché (y compris pour une rotation lancée depuis Intune). La revue des consultations porte donc sur « Recover… ».

CONSEIL **test.** Sur un poste géré, forcer l'application avec `Invoke-LapsPolicyProcessing` (PowerShell en administrateur), vérifier le compte avec `Get-LocalUser [Nom du compte local]`, puis ouvrir une session avec le mot de passe lu dans Entra ID (étape 8). Après rotation (vérifié sur le terrain), le nouveau mot de passe fonctionne et l'ancien est refusé. Les événements 10004, 10020 et 10029 du journal « Microsoft-Windows-LAPS/Operational » confirment le traitement et la sauvegarde dans Entra ID.

ATTENTION **rotation immédiate.** En cas de compromission d'un poste, la rotation se lance depuis Intune, pas depuis Entra : intune.microsoft.com → Appareils → Tous les appareils → [appareil] → menu « Sécurisé » → « Faire pivoter le mot de passe de l'administrateur(-trice) local(e) » → confirmer par « Faire pivoter le mot de passe ». L'appareil doit être en ligne. Seul un appareil à la fois peut être traité. Le droit « Tâches à distance : Rotate Local Admin Password » est requis. Un redémarrage de l'appareil peut être nécessaire pour que le nouveau mot de passe soit sauvegardé dans Entra ID (selon le texte de confirmation du portail).

Partie 5 : SmartScreen et filtrage web

5.1 Microsoft Defender SmartScreen

N°	Étape	Action
C1	Objectif	Protection du système contre les sites de phishing, les téléchargements malveillants et les applications non reconnues.
1	Chemin	intune.microsoft.com → Appareils → Windows → Configuration → Créer → Nouvelle stratégie → Plateforme : « Windows 10 et versions ultérieures » → Type de profil : « Modèles » → modèle « Protection des points de terminaison » → Créer. Le modèle est en bas de la liste (filtre de recherche inopérant sur ce nom).
2	Informations de base	Onglet « Informations de base » : Nom (par exemple `SMARTSCREEN-Windows-[Nom du client]`) → Suivant.
3	Paramètres	Onglet « Paramètres de configuration » : le modèle regroupe plusieurs sections (Application Guard, Pare-feu Windows, Chiffrement Windows, Exploit Guard, etc.). Ne déplier que « Microsoft Defender SmartScreen », qui contient deux paramètres, tous deux « Non configuré » par défaut : « SmartScreen pour les applications et les fichiers » → Activer ; « Exécution de fichiers non vérifiés » → Bloquer. Laisser les autres sections à « Non configuré ».
4	Affecter	Onglet « Attributions » → « Groupes inclus » → « Ajouter des groupes » → `GRP-Appareils-Windows` → Suivant → Créer.

INFO **SmartScreen pour Microsoft Edge.** Ce modèle ne contient aucun paramètre propre à Edge. La protection SmartScreen d'Edge relève de la configuration d'Edge et n'a pas été relevée dans ce guide : à confirmer avant de la documenter.

INFO **relevé du 8 novembre 2026.** Libellés relevés dans l'assistant, sans enregistrer de profil.

5.2 Enhanced Phishing Protection

N°	Étape	Action
C1	Objectif	Fonctionnalité Windows 11. Avertit l'utilisateur qui saisit son mot de passe Windows dans une application non approuvée ou sur un site de phishing, ou qui le réutilise. `[nLPD art. 8]`
1	Chemin	intune.microsoft.com → Appareils → Windows → Configuration → Créer → Nouvelle stratégie → Plateforme : « Windows 10 et versions ultérieures » → Type de profil : « Catalogue des paramètres » → Créer.
2	Informations de base	Onglet « Informations de base » : Nom (par exemple `EPP-Windows-[Nom du client]`) → Suivant.

N°	Étape	Action
3	Ajouter les paramètres	Onglet « Paramètres de configuration » → « Ajouter des paramètres » → dans le « Sélecteur de paramètres », chercher `Enhanced Phishing Protection` → Rechercher → catégorie « Smart Screen\ Protection avancée contre l'hameçonnage » → sous-catégorie « Protection contre l'hameçonnage améliorée » (5 résultats) → « Sélectionner tous ces paramètres » → fermer le sélecteur.
4	Valeurs	Cinq paramètres, avec leur valeur à l'ajout : « Service activé » : Activé ; « Notifier la réutilisation du mot de passe » : Désactivé ; « Avertir les personnes malveillantes » : Désactivé ; « Collecte de données automatique » : Désactivé ; « Notifier l'application non sécurisée » : Désactivé. Recommandation : garder « Service activé » et passer à Activé les trois notifications (réutilisation du mot de passe, personnes malveillantes, application non sécurisée). Laisser « Collecte de données automatique » à Désactivé, sauf décision documentée avec le client. `[nLPD art. 8]`
5	Affecter	Onglet « Balises d'étendue » → Suivant, puis « Attributions » → `GRP-Appareils-Windows` (Windows 11 uniquement : vérifier la version du système).

INFO **relevé du 8 novembre 2026.** Libellés relevés dans l'assistant, sans enregistrer de profil. Les onglets « Balises d'étendue » et « Attributions » de ce profil n'ont pas été ouverts.

5.3 Filtrage de contenu web

N°	Étape	Action
C1	Objectif	Bloquer des catégories de sites sur tous les navigateurs via Defender. Les catégories proposées sont des catégories de contenu (adulte, bande passante, responsabilité légale, loisir, sans catégorie). Les sites de phishing et de logiciels malveillants ne figurent pas dans cette liste : ils relèvent de SmartScreen (§5.1) et de la protection réseau (§4.6).
C2	Limite Defender for Business	Selon la documentation Microsoft de Defender for Business, une seule politique de filtrage de contenu web s'applique à l'organisation, sans ciblage par appareil. Ne promettez donc pas de segmentation par groupe d'appareils. L'écran relevé propose pourtant des « Groupes d'ordinateurs » (étape 4) : cet écart est à confirmer sur un tenant Business Premium seul.
C3	Méthode	1. Une politique globale. 2. Une période d'observation (rapport) avant blocage des catégories non critiques. 3. Sélection des catégories à bloquer validée par la direction. 4. Exceptions documentées dans le registre.
1	Chemin	security.microsoft.com → Paramètres → Points de terminaison → section « Règles » → « Filtrage du contenu web ». Le bouton « Ajouter une stratégie » se trouve dans le menu « Autres actions » (« … ») au-dessus de la liste.
2	Général	Assistant « Ajouter une stratégie », onglet « Général » : « Nom de la stratégie » (par exemple `WCF-[Nom du client]`) → Suivant.
3	Catégories bloquées	Onglet « Catégories bloquées » : aucune case n'est cochée par défaut. Groupes proposés : « Contenu pour adultes » (Sectes, Jeux de hasard, Nudité, Pornographie/Caractère sexuel, Éducation sexuelle, De mauvais goût, Violence), « Bande passante élevée » (Sites de téléchargement, Partage d'images, P2P, Diffusion en continu et téléchargements), « Responsabilité légale » (Images d'enfants maltraités, Activité criminelle, Piratage, Haine et intolérance, Drogue illégale, Logiciel illégal, Triche scolaire, Automutilation, Armes), « Loisir » (Conversation, Jeux, Messagerie instantanée, Réseaux professionnels, Messagerie web, Réseaux sociaux), « Sans catégorie » (Domaines immobilisés, Domaines récemment enregistrés). Chaque groupe a une case « Sélectionner tout ».

N°	Étape	Action
4	Portée	Onglet « Étendue » : « Groupes d'ordinateurs » → « Sélectionner tout » est coché par défaut (la politique s'applique alors à tous les appareils). Laisser « Sélectionner tout » : le guide ne recommande pas de restreindre la portée (voir C2). → Suivant.
5	Validation	Onglet « Récapitulatif » : relire le nom, les catégories et la portée, puis enregistrer.
6	Rapport	security.microsoft.com → Rapports → Protection web : URL bloquées par catégorie et par appareil. À confirmer lors de la première politique active.

INFO **relevé du 8 novembre 2026.** Les libellés ci-dessus ont été relevés dans l'assistant, sans enregistrer de politique.

Partie 6 : Investigation et réponse automatisée

6.1 Investigation et remédiation automatisées (AIR)

ATTENTION **changement Microsoft.** Microsoft a modifié l'architecture de l'investigation et de la remédiation automatisées : l'AIR est intégrée à l'antivirus et le déclenchement manuel est retiré (avis MC1411577, contenu détaillé à relire avant déploiement). L'ancien réglage « niveau d'automatisation » ne doit plus être présenté comme le levier principal. Le portail confirme le déplacement du réglage (étape 2). Ne promettez pas qu'une alerte élevée déclenche systématiquement une investigation distincte.

N°	Étape	Action
C1	Objectif	Contribuer à la détection et à la remédiation des menaces sans équipe de sécurité dédiée. `[nLPD art. 8]`
1	Vérifier Defender Antivirus	Vérifier que l'antivirus est actif sur les postes gérés (Partie 4) : l'AIR en dépend. Sur un poste : PowerShell en administrateur → `Get-MpComputerStatus` (vérifier `AntivirusEnabled`).
2	Paramètres d'automatisation	Le réglage n'est plus dans les paramètres Points de terminaison : security.microsoft.com → Paramètres → Points de terminaison → Général → « Correction automatique » affiche « La correction automatique a été déplacée » avec le bouton « Allez-y maintenant ». Ce bouton ouvre Paramètres → Microsoft Defender XDR → Règles → « Réponse automatisée » → « Appareils » (page « Réponse automatisée des appareils », « Exclure les appareils des actions de réponse automatisées »).
3	Lire la page	Onglets « Groupes d'appareils », « Adresses IP » et « Application de la stratégie ». Tableau des groupes d'appareils : colonnes « Rang », « Groupe d'appareils », « Appareils », « Niveau de correction », « Interruption d'attaque », « Description », « Groupes d'utilisateurs ». Sur un tenant sans groupe d'appareils défini, le tableau est vide : aucun niveau n'est à régler ici.
4	Centre de notifications	security.microsoft.com → Enquête et réponse → Actions et envois → « Centre de notifications » (adresse `/action-center/pending`). Onglets « En attente » et « Historique ». Colonnes : « Heure de mise à jour d'action », « ID d'examen », « ID d'approbation », « Type d'action », « Détails », « Type d'entité », « Désignation », « Décision », « État ». Lien « Notifications par e-mail » en haut à droite pour être averti. Désigner une personne qui l'examine à fréquence définie.
5	Documentation	Consigner dans le registre de sécurité du client chaque action corrective notable, avec date, appareil et décision.

INFO **résultat attendu.** Les menaces détectées par Defender sont traitées selon la configuration, et leurs actions apparaissent dans le Centre de notifications (anciennement Centre d'actions). Le comportement exact en cas d'alerte élevée n'a pas été observé : il est à relever sur un poste réel.

6.2 Mode de dépannage

N°	Étape	Action
C1	Objectif	Permet aux administrateurs locaux de modifier, sur un poste précis, des configurations normalement verrouillées par la stratégie, pour diagnostiquer un conflit (impact de l'antivirus sur les performances, compatibilité d'applications). N'affecte pas les autres postes.
C2	Cas d'usage	Logiciel métier bloqué par une règle ASR. Faux positif de l'antivirus. Problème réseau lié à Network Protection.
1	Ouvrir la fiche	security.microsoft.com → Ressources → Appareils → cliquer sur le nom du poste.
2	Activer	Fiche de l'appareil → menu « … » en haut à droite → « Activer le mode de dépannage ». Un panneau « Activer le mode de dépannage pour ce périphérique » s'ouvre : il rappelle que les administrateurs locaux pourront modifier les configurations verrouillées et que le mode dure 4 heures. Bouton « Envoyer » pour confirmer.
3	Durée	4 heures par séance, d'après le panneau. La documentation Microsoft limite aussi chaque appareil à 8 heures cumulées, quota remis à zéro 24 heures après la première activation. L'activation peut prendre jusqu'à 15 minutes.
4	Données de diagnostic	Les journaux générés pendant le mode de dépannage restent accessibles selon la stratégie de rétention de l'organisation. Ils peuvent être collectés avec « Collecter le package d'enquêtes » (même menu « … » de la fiche).

ATTENTION **audit.** L'activation du mode de dépannage est journalisée. Documentez toujours le motif.

INFO **relevé du 8 novembre 2026.** Le panneau a été ouvert puis fermé sans confirmer : le mode n'a pas été activé sur le poste de test.

INFO **À CONFIRMER : disponibilité avec Defender for Business.** La documentation Microsoft sur le mode de dépannage cite Defender for Endpoint Plan 1 et Plan 2, sans nommer Defender for Business. Elle précise aussi que l'option « Activer le mode de dépannage » s'affiche même pour un appareil qui ne remplit pas les prérequis : la voir dans le portail ne prouve pas que la fonction marche. Prérequis cités : rôle Administrateur de la sécurité (ou rôle personnalisé avec « Paramètres de sécurité de base (gérer) » et « Réglage de la détection (gérer) »), appareil actif dans Defender for Endpoint, plateforme antivirus récente. Ne pas promettre cette fonction au client avant de l'avoir testée sur son tenant.

INFO **ce que le mode permet.** Les administrateurs locaux peuvent modifier des paramètres de l'antivirus normalement verrouillés par la stratégie et désactiver temporairement la protection contre les falsifications (Tamper Protection, appareil en ligne). Ils ne peuvent ni désactiver ni désinstaller l'antivirus. À la fin de la séance, les paramètres reviennent à leurs valeurs d'origine et la protection est réactivée ; les modifications de stratégie reçues pendant la séance ne s'appliquent qu'après.

Partie 7 : Gestion des vulnérabilités

N°	Étape	Action
C1	Objectif	Identifier les failles connues (CVE) sur les logiciels installés et recommander des corrections priorisées. Mesure technique `[nLPD art. 8]`.
C2	Contenu	Inventaire des logiciels, détection des CVE actives, score d'exposition, recommandations priorisées.
1	Tableau de bord	security.microsoft.com → Gestion de l'exposition → Gestion des vulnérabilités → Vue d'ensemble (page « Tableau de bord Gestion des vulnérabilités de Microsoft Defender », adresse `/tvm_dashboard/Endpoint`). Le sous-menu contient aussi « Vulnérabilités », « Inventaires » et « Correction ». Deux onglets : « Endpoint » et « Cloud ».
2	Score d'exposition	Carte « Score d'exposition du point de terminaison », affichée sur 100, avec un graphique « au fil du temps » et le lien « Améliorer le score ». Un bandeau signale que le calcul du score change (nouveau modèle en cours de déploiement) : des variations, y compris des baisses, sont attendues sans nouvelle vulnérabilité. L'objectif de 30 ou moins reste une proposition à valider sur des tenants réels.
3	Autres cartes	« Principales recommandations sur les points de terminaison », « Principaux événements impactants », « Principal logiciel vulnérable », « Informations sur les vulnérabilités », « Répartition d'exposition du périphérique », « Principales activités de correction », « Principaux périphériques exposés ».
4	Recommandations	Depuis le tableau de bord, lien « Afficher les recommandations relatives aux points de terminaison » (page « Recommandations de sécurité », adresse `/security-recommendations`). Filtre par défaut « État : Actif ». Colonnes : « Recommandation liée à la sécurité », « Plateforme du système d'exploitation », « Faiblesses », « Appareils critiques exposés », « Composant connexe », « Menaces », « Appareils exposés », « Type de correction », « Activités de correction », « Impact », « Balises ». Cliquer sur le titre de la colonne « Impact » pour trier, puis traiter en priorité les plus élevés.
5	Inventaire	Gestion de l'exposition → Gestion des vulnérabilités → Inventaires (page « Inventaires »). Onglets « Logiciel » et « Composants logiciels ». Colonnes : « Nom », « Plateforme du système d'exploitation », « Fournisseur », « Faiblesses », « Menaces », « Appareils exposés », « Impact », « Balises ». Repérer la balise « Versions en fin de support » pour identifier les logiciels non supportés.
6	Remédiation	Ouvrir une recommandation → bouton « Demander une correction ». Assistant en trois étapes : « Vérifier les options de correction » (étapes proposées par Microsoft), « Demande de correction », « Vérifier et finaliser ». À l'étape « Demande de correction » : « Date d'échéance de la correction » (obligatoire), « Priorité » (par défaut Moyen), « Ajouter des notes ». Le panneau précise qu'aucune modification n'est appliquée automatiquement aux appareils : la correction reste à faire à la main ou par une stratégie Intune (Parties 4 et 5).
7	Suivi	Gestion de l'exposition → Gestion des vulnérabilités → Correction. Onglets « Activités » et « Exceptions ». Colonnes notables : « État de la correction d'appareils », « Progression de la correction de l'appareil », « Statut de ticket », « Date d'échéance de la correction », « Temps restant jusqu'à l'échéance ». Le bouton « Options de l'exception » d'une recommandation sert à documenter une exception.

INFO **À CONFIRMER : ticket Intune.** À l'étape « Demande de correction », la case « Ouvrir un ticket dans Intune (pour les appareils joints à AAD) » est grisée sur le tenant relevé, et la colonne « Statut de ticket » affiche « Aucun ticket ». La condition qui active cette case (connexion Defender et Intune, type d'appareil) n'est pas établie : ne pas promettre au client une tâche automatique dans Intune.

INFO **relevé du 8 novembre 2026.** L'assistant « Demander une correction » a été ouvert puis annulé sans l'envoyer. Le volet de détail d'une recommandation affichait une erreur à l'ouverture (« Un problème est survenu ») : les boutons « Demander une correction » et « Options de l'exception » restaient accessibles.

CONSEIL **fréquence.** Revue mensuelle des recommandations critiques, revue trimestrielle de l'inventaire logiciel.

Partie 7bis : Prise en main à distance

Deux options, complémentaires. Le choix dépend de la licence du client et du besoin de traçabilité.

Option A : Quick Assist (inclus dans Windows)

N°	Étape	Action
C1	Ce que c'est	Outil natif de Windows 10 et 11, sans configuration. Le technicien génère un code, l'utilisateur le saisit, la session s'ouvre.
C2	Limites	Aucune intégration Intune, pas de journal centralisé, pas d'accès sans l'utilisateur présent. Adapté aux PME sans exigence d'audit centralisé.
1	Technicien	Démarrer → Quick Assist → Aider quelqu'un → un code est généré (durée de validité courte).
2	Utilisateur	Démarrer → Quick Assist → Obtenir de l'aide → saisir le code → partager l'écran ou donner le contrôle.

Option B : Remote Help (Intune)

ATTENTION **licence à vérifier.** Remote Help n'est pas couvert par Intune Plan 1 seul. Selon le tenant, il nécessite une licence complémentaire (add-on Remote Help, Intune Plan 2 ou Intune Suite). Vérifiez les licences effectives sur la page officielle Microsoft et auprès du revendeur avant de proposer cette option. Les deux participants à une session (technicien et utilisateur aidé) doivent être couverts par la licence nécessaire. Les prix ne figurent pas dans ce guide.

N°	Étape	Action
C1	Ce que c'est	Prise en main à distance intégrée à Intune. Sessions journalisées, liées à l'appareil Intune et à l'identité Entra ID du technicien.
C2	Accès sans utilisateur	La disponibilité du mode « sans utilisateur » (unattended) doit être vérifiée : licence, version du client, et région du tenant. Une restriction a été signalée pour certaines régions dont Switzerland North : à confirmer sur la documentation Microsoft avant de promettre ce mode au client. Selon la documentation Microsoft, le mode sans utilisateur exige en plus l'agent Azure Virtual Desktop et son bootloader sur le poste.
1	Activer	intune.microsoft.com → Administrateur de locataire → « Assistance à distance ». Trois onglets : « Surveiller », « Paramètres », « Séances d'Assistance à distance ». Onglet « Paramètres » → « Configurer » → « Activer l'Assistance à distance » (désactivée par défaut), « Autoriser l'Assistance à distance aux appareils désinscrits » (« Non autorisée » par défaut), « Désactiver la conversation » (« Non » par défaut) → Enregistrer.

N°	Étape	Action
2	Licence	Sans module complémentaire, les trois champs du panneau « Configurer l'Assistance à distance » sont grisés et le bouton « Enregistrer » est inactif, et un bandeau propose d'essayer ou d'obtenir le module. Le module est listé sous Administrateur de locataire → « Modules complémentaires Intune » (entrée « Assistance à distance », à côté de « Microsoft Intune Suite », « Intune plan 2 » et « Gestion des privilèges de points de terminaison »).
3	Rôles	La page indique que l'administrateur du support et l'utilisateur qui reçoit l'aide doivent être configurés dans les rôles (Administrateur de locataire → « Rôles »). Les autorisations exactes n'ont pas été relevées : module non disponible sur le tenant.
4	Déployer le client	Le client n'est pas un type d'application de la liste « Sélectionner le type d'application » d'Intune (types : Application Microsoft Store nouvelle ou héritée, Microsoft Edge, Microsoft 365 Apps, Lien web, Application métier, Application Windows (Win32)). La recherche « Remote Help » dans « Application Microsoft Store (nouvelle) » n'a rien retourné. Selon la documentation Microsoft : télécharger l'installeur sur `aka.ms/downloadremotehelp`, le renommer `remotehelpinstaller.exe`, le convertir en `.intunewin`, puis Applications → Windows → Créer → « Application Windows (Win32) ». Commande d'installation : `remotehelpinstaller.exe /quiet acceptTerms=1`. Commande de désinstallation : `remotehelpinstaller.exe /uninstall /quiet acceptTerms=1`. Règle de détection : fichier `RemoteHelp.exe` dans `C:\Program Files\Remote Help`, version supérieure ou égale à celle déployée. Les options `acceptTerms` et `enableAutoUpdates` sont sensibles à la casse.
5	Affecter	Attribuer l'application à `GRP-Appareils-Windows` (groupe d'appareils : la documentation précise de ne pas affecter à des groupes d'utilisateurs).
6	Session technicien	Ouvrir Remote Help, se connecter avec le compte Entra ID, saisir le code de l'utilisateur. Non relevé : module non disponible sur le tenant.
7	Journaux	Administrateur de locataire → Assistance à distance → onglet « Séances d'Assistance à distance » (colonnes « ID du fournisseur », « ID du destinataire », « Nom du destinataire »…). Une note précise qu'une séance de plus de 4 heures ou terminée sur une erreur y est signalée. L'onglet « Surveiller » affiche les séances actives, la durée moyenne et le nombre total de séances.

INFO **relevé du 8 novembre 2026.** Menus relevés sans rien enregistrer. Le déploiement du client suit la documentation Microsoft (https://learn.microsoft.com/en-us/intune/remote-help/deploy), non testée sur ce tenant faute de licence. L'onglet « Séances d'Assistance à distance » affichait une erreur de chargement à l'ouverture.

Partie 8 : Politiques de conformité

nLPD art. 8 al. 1 : contrôle d'accès par état de sécurité de l'appareil. Les politiques de conformité définissent les critères de sécurité requis pour accéder aux ressources M365. Un appareil non conforme est bloqué par CA-08 (guide Entra ID P1), une fois cette politique passée en Application (Partie 12).

8.1 Conformité Windows

N°	Étape	Action
C1	Critères	BitLocker activé. Antivirus Microsoft Defender actif et à jour. Pare-feu Windows actif. Secure Boot activé. Délai de verrouillage : 15 minutes maximum. Score de risque Defender : « Faible » au plus (nécessite le connecteur §0.3).
C2	Version minimale	Windows 11, dans la plus ancienne version encore supportée au moment du déploiement (vérifier le cycle de vie Microsoft). Windows 10 n'est plus une version standard : prévoir une exception documentée pour les appareils sous ESU et les éditions LTSC, jamais de valeur par défaut.
C3	Délai de grâce	3 jours avant le marquage « Non conforme ».
1	Chemin	intune.microsoft.com → Appareils → Conformité → onglet « Stratégies » → « Créer une stratégie » → Plateforme : « Windows 10 et versions ultérieures » → Type de profil : « Stratégie de conformité Windows 10/11 » (l'autre choix est « Templates ») → Créer. Plateformes proposées : Administrateur(-trice) d'appareil Android, Android (AOSP), Android Enterprise, iOS/iPadOS, Linux, macOS, Windows 10 et ultérieures, Windows 8.1 et ultérieures.
2	Informations de base	Onglet « Informations de base » : Nom (par exemple `CONF-Windows-[Nom du client]`) → Suivant.
3	Paramètres de conformité	Sept sections : « Conformité personnalisée », « Intégrité de l'appareil », « Propriétés de l'appareil », « Conformité de Configuration Manager », « Sécurité système », « Microsoft Defender for Endpoint », « Sous-système Windows pour Linux (WSL) ». Tous les paramètres sont « Non configuré » par défaut.
4	Intégrité de l'appareil	« BitLocker » → Exiger. « Démarrage sécurisé » → Exiger. « Intégrité du code » : à décider selon le parc.
5	Propriétés de l'appareil	« Version minimale du système d'exploitation » (champ de saisie ; existent aussi « Version maximale », les versions minimale et maximale pour les appareils mobiles et « Builds de système d'exploitation valides »). Valeur selon C2.
6	Sécurité système	Groupe « Mot de passe » : « Exiger un mot de passe pour déverrouiller les appareils mobiles », « Longueur minimale du mot de passe », « Nombre maximal de minutes d'inactivité avant demande du mot de passe » (le délai de verrouillage de C1). Groupe « Chiffrement » : « Exige le chiffrement du stockage de données sur l'appareil ». Groupe « Sécurité de l'appareil » : « Pare-feu » → Exiger, « Module de plateforme sécurisée (TPM) », « Antivirus » → Exiger, « Logiciel anti-espion ». Groupe « Defender » : « Logiciel anti-programme malveillant Microsoft Defender » → Exiger, « Version minimale du logiciel anti-programme malveillant Microsoft Defender », « Veille de sécurité du logiciel anti-programme malveillant Microsoft Defender à jour », « Protection en temps réel ».
7	Score de risque	Section « Microsoft Defender for Endpoint » : « Exiger que l'appareil ait un score inférieur ou égal au score de risque machine » (liste déroulante, « Non configuré » par défaut). Le lien « Règles Microsoft Defender pour point de terminaison » s'y trouve. Cette règle dépend du connecteur §0.3.
8	Actions	Onglet « Actions en cas de non-conformité » (§8.4) → Suivant.
9	Affecter	Onglet « Attributions » : « Groupes inclus » → « Ajouter des groupes » (ou « Ajouter tous les utilisateurs », « Ajouter tous les appareils ») → `GRP-Appareils-Windows` ; « Groupes exclus » → « Ajouter des groupes ». Suivant → Créer.

ATTENTION **appareils sans stratégie.** Intune → Appareils → Conformité → « Paramètres de stratégie de conformité » : « Marquer les appareils sans stratégie de conformité comme étant » est sur « Conforme » à l'état d'origine, avec une « Période de validité de l'état de conformité (jours) » de 30. Avec la valeur « Conforme », un appareil sans stratégie de conformité n'est jamais bloqué par CA-08. Recommandation : passer ce paramètre sur « Non conforme » (bouton « Enregistrer »), après avoir vérifié l'effet sur les appareils existants.

INFO **relevé du 8 novembre 2026.** Libellés relevés dans l'assistant, sans enregistrer de stratégie.

INFO **délai de grâce, ce que montre le portail.** Après désactivation de BitLocker (`manage-bde -off C:`) et synchronisation, la page de l'appareil « Conformité de l'appareil » affiche aussitôt la stratégie en « Non conforme », alors que la fiche de l'appareil affiche le badge « En période de grâce » et la liste « Tous les appareils » la mention « Dans la période de grâce ». Le marquage définitif « Non conforme » intervient à l'issue du délai fixé dans « Actions en cas de non-conformité » (colonne « Planification (jours après la non-conformité) », 0 par défaut, 3 dans ce guide). Prévoir ce délai dans le calendrier de test de la §12.2 (CA-08).

CONSEIL **fin du délai de grâce, relevé terrain.** Avec un délai de 3 jours, l'appareil testé affichait le badge rouge « Non conforme » sur sa fiche (à côté de « Entreprise » et « Intune ») au quatrième jour, et le cadre « État de conformité de l'appareil » indiquait « Conforme : 2 » et « Non Conforme : 1 » pour trois stratégies. Le dernier échange de l'appareil affiché sur la fiche (« Dernier check-in ») datait du premier jour : le basculement s'est donc fait sans nouvelle synchronisation visible, à l'échéance du délai.

INFO **appareil neuf non conforme au départ.** Un poste fraîchement provisionné peut apparaître « Non conforme » tant que les signatures Microsoft Defender ne sont pas à jour (critère « Veille de sécurité ... à jour »). Il passe « Conforme » après la mise à jour des signatures (`Update-MpSignature` sur le poste, ou « Mettre à jour les informations de Defender » dans le menu « Sécurisé » de l'appareil). Ne pas diagnostiquer une panne avant ce délai.

8.2 Conformité iOS

N°	Étape	Action
C1	Critères	Version iOS minimale à réévaluer au moment du déploiement (proposition de départ : iOS 16, à relever). Code de verrouillage de 6 chiffres minimum. Délai de verrouillage : 5 minutes maximum. Jailbreak non détecté.
1	Chemin	Appareils → Conformité → Stratégies → Créer une stratégie → Plateforme : « iOS/iPadOS » (le type de profil est alors imposé : « Politique de conformité iOS ») → Créer. Nom par exemple `CONF-iOS-[Nom du client]`.
2	Paramètres	Cinq sections : « E-mail », « Intégrité de l'appareil », « Propriétés de l'appareil », « Microsoft Defender for Endpoint », « Sécurité système ».
3	Intégrité	« Appareils jailbreakés » → Bloquer. « Exiger que l'appareil se situe au niveau de menace d'appareil ou en dessous » : liste déroulante, « Non configuré » par défaut.
4	Propriétés	« Version minimale du système d'exploitation », « Version maximale », « Version de build minimale », « Version de build maximale » (champs de saisie).

N°	Étape	Action
5	Sécurité système	« Exiger un mot de passe pour déverrouiller les appareils mobiles » → Exiger. Le texte du portail précise que cette option applique automatiquement un code confidentiel complexe à 6 chiffres sur tous les appareils inscrits par l'utilisateur, quels que soient les autres réglages. Autres paramètres : « Mots de passe simples », « Longueur minimale du mot de passe » (4 à 14), « Type de mot de passe obligatoire », « Nombre maximal de minutes d'inactivité avant le verrouillage de l'appareil » (délai de verrouillage), « Expiration du mot de passe (jours) », « Nombre de mots de passe précédents avant d'autoriser leur réutilisation », « Applications restreintes ».
6	Affecter	Onglet « Attributions » → `GRP-Appareils-iOS`. Un bandeau de la page « Stratégies » rappelle qu'un connecteur Threat Defense actif pour iOS/iPadOS exige une stratégie de conformité avec la règle de niveau de menace de l'appareil.

8.3 Conformité Android

N°	Étape	Action
C1	Critères	Android 9 est trop ancien comme niveau minimal pour un socle de sécurité actuel. Version minimale : proposition Android 12, à valider sur le parc client et sur la documentation Intune. Code de verrouillage de 6 chiffres minimum. Root non détecté.
C2	Intégrité de l'appareil	Choisir le niveau de vérification Play Integrity (de base, appareil, fort). Pour Android 13 et ultérieur, le niveau « fort » (Strong Integrity) exige notamment des mises à jour de sécurité de moins de 12 mois (règle Google, appliquée par Intune). La date d'application côté Intune est à confirmer dans le centre de messages Microsoft du client. Vérifier la conformité actuelle des modèles du client avant d'exiger ce niveau, et ne pas l'imposer d'office aux appareils personnels (BYOD).
1	Chemin	Appareils → Conformité → Stratégies → Créer une stratégie → Plateforme : « Android Enterprise » → Type de profil : « Profil professionnel complètement managé, dédié et appartenant à l'entreprise » ou « Profil de travail personnel ». La plateforme « Administrateur(-trice) d'appareil Android » existe encore dans la liste, mais un bandeau de la page rappelle la fin du support de ce mode depuis le 31 décembre 2024 : ne pas l'utiliser. Nom par exemple `CONF-Android-[Nom du client]`.
2	Paramètres	Pour « Profil de travail personnel » : quatre sections, « Microsoft Defender for Endpoint », « Intégrité de l'appareil », « Propriétés de l'appareil », « Sécurité système ». Le type « Profil professionnel complètement managé… » n'a pas été ouvert.
3	Intégrité	« Appareils rootés » → Bloquer. « Exiger que l'appareil se situe au niveau de menace d'appareil ou en dessous ». Groupe « Google Play Protect » : « Google Play Services est configuré », « Fournisseur de sécurité à jour » (Exiger), « Jouer le verdict d'intégrité » : « Non configuré », « Vérifier l'intégrité de base » ou « Vérifier l'intégrité de base et l'intégrité de l'appareil ». Aucun niveau « fort » n'est proposé dans ce type de profil.
4	Propriétés	« Version minimale du système d'exploitation », « Version maximale du système d'exploitation » (champs de saisie).
5	Sécurité système	« Exige le chiffrement du stockage de données sur l'appareil », « Bloquer les applications provenant de sources inconnues », « Intégrité du runtime de l'application Portail d'entreprise », « Bloquer le débogage USB sur l'appareil », « Niveau minimal du correctif de sécurité », « Exiger un mot de passe pour déverrouiller les appareils mobiles ». Le groupe « Tous les appareils Android » contient les réglages de mot de passe (non déroulés).
6	Affecter	Onglet « Attributions » → `GRP-Appareils-Android`.

INFO **relevé du 8 novembre 2026.** Relevé réalisé sur le type « Profil de travail personnel » uniquement. Le paramètre « Jouer le verdict d'intégrité » peut offrir d'autres niveaux dans l'autre type de profil : à relever avant de promettre le niveau « fort » au client.

8.4 Actions en cas de non-conformité

N°	Étape	Action
C1	Séquence recommandée	J+0 : e-mail automatique à l'utilisateur. J+3 : appareil marqué non conforme, donc bloqué par CA-08 une fois CA-08 en Application (à condition que la première action soit bien reportée à 3 jours : voir l'étape 2 ; sinon le blocage est immédiat). J+14 : e-mail d'escalade au responsable. J+30 : ajout de l'appareil à la liste des appareils à retirer.
C2	Le retrait n'est pas automatique	L'ajout à la liste des appareils à retirer ne retire pas l'appareil. Un administrateur doit valider explicitement le retrait. Pour les appareils personnels (BYOD), documentez cette validation avant de supprimer des données d'entreprise.
1	Modèle de message	Avant l'action e-mail : Appareils → Conformité → « Notifications » → « Créer une notification » (modèles de messages de notification : colonnes « Nom d'affichage » et « Dernière modification »). Nom par exemple `NOTIF-NonConformite-[Nom du client]`. La liste est vide à l'état d'origine.
2	Configurer	Dans l'assistant de chaque stratégie, onglet « Actions en cas de non-conformité » : tableau « Action », « Planification (jours après la non-conformité) », « Modèle de message », « Destinataires supplémentaires ». La première ligne « Marquer l'appareil comme non conforme » est préremplie sur « Immédiatement ». Ajouter une ligne : « Envoyer un e-mail à l'utilisateur final » ou « Ajouter un appareil à la liste des mises hors service », avec le nombre de jours. Tant que cette première ligne reste sur « Immédiatement », un appareil non conforme est bloqué par CA-08 sans délai. La possibilité de la reporter à 3 jours (délai de grâce de C3) n'a pas été testée : à valider avant d'annoncer le blocage à J+3 au client.
3	Valider le retrait	Appareils → Conformité → « Mettre hors service les appareils non conformes » : liste des appareils ajoutés à la liste de retrait (colonnes « Nom de l'appareil », « État de conformité », « Système d'exploitation »…, boutons « Actualiser », « Exporter », « Colonnes »). Vide à l'état d'origine (« Aucun appareil non conforme au retrait trouvé »). Le bouton de retrait qui apparaît à la sélection d'un appareil n'a pas été observé : à relever sur un appareil réel.

INFO **relevé du 8 novembre 2026.** Le libellé du portail est « Ajouter un appareil à la liste des mises hors service ». L'action ne retire pas l'appareil : elle l'inscrit dans la liste ci-dessus, d'où l'étape 3.

Partie 9 : Profils de configuration

9.1 Windows Hello Entreprise

N°	Étape	Action
C1	Objectif	Remplace le mot de passe Windows par une biométrie ou un code PIN lié à l'appareil, résistant au hameçonnage. `[nLPD art. 8]` Recommandé, mais pas documenté par Microsoft comme prérequis de Token Protection (voir guide Entra, Partie 6).

N°	Étape	Action
1	Chemin	intune.microsoft.com → Appareils → Intégration de l'appareil → Inscription → onglet Windows → Windows Hello Entreprise. La page s'ouvre sur un volet « Inscription Windows » nommé « All users and all devices » (« Attribué à : Tous les utilisateurs »).
2	Portée	Ce paramètre est unique pour tout le tenant : il n'y a pas d'affectation à un groupe à cette étape. Pour cibler certains utilisateurs ou appareils, il faut un profil de configuration distinct (non couvert par ce guide).
3	Activation	« Configurer Windows Hello Entreprise » → Activé. « Utiliser un module de plateforme sécurisée (TPM) » → Obligatoire (ou Préféré si des postes sans TPM sont encore en service).
4	Code PIN	Libellés présents : « Longueur minimale du code PIN », « Longueur maximale du code PIN », « Lettres minuscules dans le code PIN », « Lettres majuscules dans le code PIN », « Caractères spéciaux dans le code PIN » (Autorisé, Obligatoire ou Non autorisé), « Expiration du code confidentiel (en jours) », « Conserver l'historique des codes confidentiels ». Valeur de départ proposée : longueur minimale de 6, expiration « Jamais » (le PIN est lié à l'appareil, son changement périodique n'est pas recommandé). À ajuster selon la politique du client. `[nLPD art. 8]`
5	Biométrie et connexion	« Autoriser l'authentification biométrique » → Oui si le matériel le permet. Autres libellés du volet : « Utiliser la détection d'usurpation avancée, si disponible », « Autoriser la connexion par téléphone », « Activer la sécurité de connexion renforcée », « Utiliser des clés de sécurité pour la connexion ».
6	Enregistrer	Enregistrer.

ATTENTION **décision à l'échelle du tenant.** Ce paramètre s'applique à « Tous les utilisateurs » et à tous les appareils. Avant de l'activer, vérifier l'impact sur les utilisateurs et les appareils déjà inscrits, et prévenir les utilisateurs.

INFO relevé en lecture seule sur le portail. Le moment où un poste déjà inscrit propose Windows Hello et la présence d'un éventuel réglage de récupération du code PIN entre « Conserver l'historique des codes confidentiels » et « Autoriser l'authentification biométrique » sont à confirmer lors de la validation terrain. La valeur de départ de l'étape 4 est une recommandation du guide, pas une valeur imposée par Microsoft.

9.2 Windows Update for Business

N°	Étape	Action
C1	Anneaux	Anneau Pilote (groupe informatique, 2 à 3 postes) : mises à jour rapides. Anneau Production (tous les postes) : délai de 7 jours pour les mises à jour de sécurité, 90 jours pour les mises à jour de fonctionnalités. Valeurs de départ, à ajuster.
1	Chemin	intune.microsoft.com → Appareils → Windows → Gérer les mises à jour → Mises à jour Windows → onglet « Anneaux de mise à jour » → Créer un profil. L'assistant s'intitule « Créer Mettre à jour l'anneau pour Windows 10 et versions ultérieures » et compte quatre pages : Informations de base, Paramètres d'anneau de mise à jour, Attributions, Vérifier + créer.
2	Anneau Pilote : base	Nom : `WUFB-Pilote-[Nom du client]`. Description libre → Suivant.
3	Anneau Pilote : paramètres	Page « Paramètres d'anneau de mise à jour ». « Mises à jour de produits Microsoft » → Accorder. « Pilotes Windows » → Accorder. « Période de report des mises à jour qualité (jours) » → 0. « Période de report des mises à jour des fonctionnalités (jours) » → 0. Laisser « Activer les versions préliminaires » sur Non configuré.

N°	Étape	Action
4	Anneau Pilote : expérience	« Comportement des mises à jour automatiques » (liste, valeur par défaut « Installation automatique à l'heure… »), « Début des heures actives » et « Fin des heures actives » (8:00 et 17:00 par défaut) à adapter aux horaires du client. « Utiliser des paramètres d'échéance » : Non configuré par défaut ; si activé, trois champs apparaissent : « Échéance des mises à jour des fonctionnalités » et « Échéance des mises à jour qualité » (0 à 30 jours), « Période de grâce » (0 à 7 jours), ainsi que « Redémarrage automatique avant l'échéance ».
5	Anneau Production	Répéter les étapes 1 à 4 avec le nom `WUFB-Production-[Nom du client]`. « Période de report des mises à jour qualité (jours) » → 7. « Période de report des mises à jour des fonctionnalités (jours) » → 90 (valeurs de départ du guide, voir C1).
6	Attributions	Page « Attributions » : affecter l'anneau Pilote au groupe pilote et l'anneau Production à `GRP-Appareils-Windows`, en excluant le groupe pilote de l'anneau Production. Le groupe pilote est créé séparément en appartenance « Affecté ». Libellés exacts de la page non relevés.
7	Vérifier + créer	Vérifier le résumé → Créer.

INFO page « Paramètres d'anneau de mise à jour » relevée en lecture seule, sans création d'anneau. La page « Attributions » n'a pas été ouverte (libellés à confirmer), et les plafonds des champs de report ne sont pas affichés dans l'assistant : les valeurs 7 et 90 jours sont à valider. Le portail affiche aussi une carte « Activation de Hotpatch » et un avertissement « Windows 10 est arrivé à la fin du support le 14 octobre 2025 » : les postes encore sous Windows 10 ne reçoivent plus de mises à jour de sécurité standard. Un anneau de mise à jour existant sur le tenant n'est pas documenté ici.

9.3 Restrictions des appareils et messagerie mobile

N°	Étape	Action
1	Objectif	Empêcher l'usage de comptes Microsoft personnels sur les postes de l'entreprise. Les réglages relevés pour cela sont décrits aux étapes 2c et 2d. Aucun réglage nommé « expériences grand public » n'a été trouvé dans les catégories ouvertes (voir 2d).
2	Chemin	intune.microsoft.com → Appareils → Windows → Configuration → Créer → Nouvelle stratégie. Plateforme : « Windows 10 et versions ultérieures ». Type de profil : « Modèles » (les autres choix sont « Catalogue des paramètres » et « Catalogue de propriétés ») → rechercher « Restrictions » → « Restrictions d'appareil » → Créer. L'assistant compte trois pages : Informations de base, Paramètres de configuration, Attributions.
2b	Catégories	Page « Paramètres de configuration », catégories relevées : Magasin d'applications, Mobile et connectivité, Cloud et stockage, Imprimante cloud, Panneau de configuration et paramètres, Affichage, Général, Expérience d'écran verrouillé, Messagerie, Ancienne version de Microsoft Edge (version 45 et antérieure), Proxy réseau, Mot de passe, Exceptions de confidentialité par application, Personnalisation, Imprimante, Confidentialité, Projection, Création de rapports et télémétrie, Rechercher, Démarrer, Microsoft Defender SmartScreen, Windows à la une, Microsoft Defender Antivirus, Paramètres d'alimentation. Nom proposé : `RESTR-Windows-[Nom du client]` (champ « Nom » de la page « Informations de base »). Tous les réglages sont à « Non configuré » par défaut.

N°	Étape	Action
2c	Compte Microsoft	Catégorie « Cloud et stockage » : « Compte Microsoft » (Bloquer / Non configuré), « Compte non-Microsoft » (Bloquer / Non configuré), « Synchronisation des paramètres du compte Microsoft » (Bloquer / Non configuré), « Assistant Connexion avec un compte Microsoft » (liste, « Non configuré » par défaut). Pour interdire les comptes Microsoft personnels : « Compte Microsoft » → Bloquer. L'effet exact sur les applications qui utilisent un compte Microsoft (à confirmer) : tester sur un poste pilote avant déploiement général.
2d	Windows à la une	Catégorie « Windows à la une » : « Windows à la une » et « Windows à la une sur l'écran de verrouillage » (Bloquer / Non configuré). Ce sont les réglages relevés les plus proches des contenus grand public. Les catégories « Général » (capture d'écran, caméra, stockage amovible, géolocalisation, Cortana...) et « Confidentialité » (« Expérience de confidentialité », « Personnalisation des entrées », « Publier les activités de l'utilisateur »...) ont aussi été relevées, sans réglage nommé « expériences grand public ». Les catégories « Magasin d'applications », « Démarrer » et « Rechercher » n'ont pas été ouvertes.
3	Messagerie iOS	intune.microsoft.com → Appareils → Apple mobile → Configuration → Créer → Nouvelle stratégie. Plateforme « iOS/iPadOS » (autres choix : tvOS, visionOS), type de profil « Modèles » (ou « Catalogue des paramètres ») → modèle « Email ». L'assistant compte quatre pages : Informations de base, Paramètres de configuration, Attributions, Vérifier + créer. Nom proposé : `MAIL-iOS-[Nom du client]`. Page « Paramètres de configuration », bloc « Paramètres de compte Exchange ActiveSync » : « Serveur e-mail » (obligatoire, exemple affiché : outlook.office365.com), « Nom de compte », « Attribut de nom d'utilisateur de Microsoft Entra ID », « Attribut d'adresse e-mail de Microsoft Entra ID », « Méthode d'authentification » (Certificat, Nom d'utilisateur et mot de passe, Information d'identification dérivée), « SSL » (Activer par défaut), « OAuth » (Désactiver par défaut : l'activer pour l'authentification moderne). Bloc « Configuration du profil Exchange ActiveSync » : « Données Exchange à synchroniser » (« Toutes les données » par défaut), « Autoriser les utilisateurs à modifier les paramètres de synchronisation » (« Oui » par défaut). Le choix de la méthode d'authentification avec OAuth, les valeurs d'attribut Entra ID et les réglages du bloc « Paramètres de courrier Exchange ActiveSync » sont à confirmer. Affecter à `GRP-Appareils-iOS` sur la page « Attributions ».
4	Messagerie Android	La configuration Android n'est pas identique à iOS : elle dépend de l'application de messagerie. Recommandation : Outlook pour Android avec authentification moderne, configuré par une stratégie de configuration d'application. À valider lors de la validation terrain. Affecter à `GRP-Appareils-Android`.
5	Vérification	Un appareil mobile inscrit obtient son compte Exchange sans saisie manuelle. Test à faire sur un appareil réel lors de la validation terrain (non exécuté dans ce guide).

Partie 10 : Defender for Office 365 Plan 1

> **ATTENTION** configuration dans security.microsoft.com → Courrier et collaboration → Stratégies et règles → Stratégies de menace. Pas dans Intune.

10.1 Liens fiables (Safe Links)

N°	Étape	Action
C1	Fonctionnement	Réécrit les URL des e-mails, vérifie au moment du clic, et peut bloquer après livraison une URL devenue malveillante. `[nLPD art. 8]`
1	Chemin	security.microsoft.com → Courrier et collaboration → Stratégies et règles → Stratégies de menace → section « Stratégies » → Liens fiables. Seule la stratégie « Built-in protection (Microsoft) » existe au départ. Cliquer sur « + » (Créer). L'assistant « Créer une stratégie de liens approuvés » compte cinq pages : Nommez votre stratégie, Utilisateurs et domaines, Paramètres de protection des URL et de protection en cas de clic, Notification & Url, Évaluation.
2	Nom	Nom : `SAFELINKS-[Nom du client]` (champ obligatoire), Description facultative → Suivant.
3	Portée	Page « Utilisateurs et domaines » : champs « Utilisateurs », « Groupes » et « Domaines » (combinés par « Et »), et case « Exclure ces utilisateurs, groupes et domaines ». Il n'y a pas de bouton « Tous les utilisateurs » : pour couvrir toute l'organisation, saisir les domaines de messagerie du client dans « Domaines ». `[nLPD art. 8]`
4	E-mail	Page « Paramètres de protection des URL et de protection en cas de clic », section « E-mail » : « Activé : Liens fiables vérifie une liste de liens malveillants connus... » coché, avec les trois options « Appliquer des liens de Coffre aux courriers envoyés au sein de l'organisation », « Appliquer l'analyse d'URL en temps réel pour les liens suspects et les liens qui pointent vers des fichiers », « Patienter que l'analyse de l'URL se termine pour remettre le message ». Ces quatre cases sont cochées par défaut.
5	Réécriture	La case « Ne réécrivez pas les URLs, effectuez les vérifications via l'API des liens fiables uniquement » est cochée par défaut : dans ce cas les URL ne sont pas réécrites. Pour réécrire les URL (comportement décrit en C1), la décocher. Liste « Ne pas réécrire les URL suivantes dans l'e-mail » : vide par défaut (« Gérer 0 URL »).
6	Teams et Office	Sections « Teams » et « Applications Office 365 » : « Activé : liens fiables vérifie une liste de liens malveillants connus... » coché par défaut dans les deux cas. Les URL ne sont pas réécrites dans ces deux applications.
7	Clics	Section « Paramètres de protection en cas de clic » : « Suivre les clics des utilisateurs » coché par défaut. « Autoriser les utilisateurs à cliquer sur l'URL d'origine » est aussi coché par défaut : le décocher empêche un utilisateur de contourner l'avertissement (recommandation du guide). « Afficher la personnalisation de l'organisation sur les pages de notification et d'avertissement » : décoché par défaut.
8	Notification	Page « Notification & Url » : « Comment souhaitez-vous avertir vos utilisateurs ? » → « Utiliser le texte de notification par défaut » (sélectionné par défaut) ou « Utiliser le texte de notification personnalisé ». Case « Use custom URLs » (libellé affiché en anglais dans le portail). → Suivant → page « Évaluation » : récapitulatif avec les liens « Modifier le nom de la stratégie » et « Modifier les utilisateurs et les domaines » → bouton « Envoyer ».

CONSEIL **test.** Limiter d'abord la stratégie à un compte de test (champ « Utilisateurs »). Envoyer un e-mail contenant une URL depuis un compte externe, puis le lire dans Outlook. Deux contrôles : survoler le lien (ou clic droit → « Copier le lien ») pour lire l'adresse réelle, et vérifier dans les en-têtes du message la ligne `X-MS-Exchange-AtpMessageProperties: SA|SL`, qui indique que le message a été traité par Safe Attachments et Safe Links. Attendu : adresse du type `https://[région].safelinks.protection.outlook.com/?url=…`.

CONSEIL **réécriture constatée sur le tenant de validation.** Le lendemain de la création de la stratégie, les liens des e-mails d'un expéditeur du même domaine (notifications automatiques de la plateforme de supervision) arrivaient réécrits, sous la forme `https://che01.safelinks.protection.outlook.com/?url=[URL encodée]&data=…&sdata=…&reserved=0`. L'URL d'origine reste lisible dans le paramètre `url`, et le paramètre `data` contient l'adresse du destinataire et l'identifiant du tenant : ne jamais publier ni transmettre un tel lien tel quel.

CONSEIL **le test doit se faire avec un expéditeur externe qui n'est pas invité.** Un e-mail envoyé depuis une adresse externe ordinaire (une messagerie grand public) arrivait avec l'URL réécrite. En revanche, des messages envoyés depuis deux adresses qui sont des invités du tenant (comptes invités Entra) arrivaient avec l'adresse d'origine, y compris lors d'un nouvel essai le lendemain, alors que l'en-tête `SA|SL` était présent et la case « Ne réécrivez pas les URLs… » décochée. Le délai d'application de la stratégie est donc écarté pour ce cas. Le mécanisme exact n'est pas établi et n'a pas été trouvé dans la documentation Microsoft : à noter pour les clients dont les partenaires sont des invités, dont les liens peuvent ne pas être réécrits.

INFO **suivi des clics.** La table `UrlClickEvents` d'Advanced hunting n'est pas disponible avec Defender for Office 365 Plan 1 (le portail indique l'absence de licence Plan 2) : le rapport « Protection des URL » et les « Détections en temps réel » sont les seuls moyens de suivi avec Business Premium.

10.2 Pièces jointes fiables (Safe Attachments)

N°	Étape	Action
C1	Fonctionnement	Analyse les pièces jointes dans un bac à sable Microsoft. Avec « Livraison dynamique », le message est remis tout de suite sans pièce jointe, qui est rattachée une fois l'analyse terminée. Avec « Bloquer », les pièces jointes et les courriers contenant un programme malveillant sont mis en quarantaine. `[nLPD art. 8]`
1	Chemin	security.microsoft.com → Courrier et collaboration → Stratégies et règles → Stratégies de menace → section « Stratégies » → Pièces jointes fiables. Seule la stratégie « Built-in protection (Microsoft) » existe au départ. Cliquer sur « + » (Créer). L'assistant « Créer une stratégie de pièces jointes approuvées » compte quatre pages : Nommez votre stratégie, Utilisateurs et domaines, Paramètres, Évaluation.
2	Nom	Nom : `SAFEATT-[Nom du client]` (champ obligatoire), Description facultative → Suivant.
3	Portée	Page « Utilisateurs et domaines » : « Utilisateurs », « Groupes », « Domaines » (combinés par « Et ») et la case « Exclure ces utilisateurs, groupes et domaines ». Pas de bouton « Tous les utilisateurs » : saisir les domaines de messagerie du client dans « Domaines ». `[nLPD art. 8]`
4	Mode	Page « Paramètres », section « Réponse de programme malveillant inconnu pour les pièces jointes approuvées ». Quatre choix : « Désactivé » (sélectionné par défaut), « Surveiller », « Bloquer », « Livraison dynamique (messages de prévisualisation) ». Il n'existe pas de choix combiné « Blocage avec livraison dynamique ». Recommandation du guide : « Bloquer ». La « Livraison dynamique » convient si les utilisateurs ne supportent pas le délai de livraison, mais elle n'est disponible que pour les boîtes aux lettres hébergées. Le portail avertit que « Surveiller » et « Bloquer » peuvent retarder la livraison des messages.
5	Quarantaine	Champ « Stratégie de mise en quarantaine » : valeur proposée par défaut `AdminOnlyAccessPolicy` (les messages mis en quarantaine ne sont libérables que par un administrateur).

N°	Étape	Action
6	Redirection	Case « Activer la redirection » (décochée par défaut) : ne prend en charge que l'action « Surveiller ». Si cochée, une adresse e-mail est obligatoire. Laisser décochée avec « Bloquer ».
7	Validation	Page « Évaluation » : récapitulatif (« Réponse de la détection pour les pièces jointes fiables », « Rediriger les pièces jointes », « Stratégie de mise en quarantaine », « Bloquer les pièces jointes non analysées », lien « Modifier les paramètres ») → bouton « Envoyer ». Le réglage « Bloquer les pièces jointes non analysées » (désactivé par défaut) est affiché sur cette page ; sa case dans la page « Paramètres » n'a pas été relevée.

CONSEIL **test.** Limiter d'abord la stratégie à un compte de test. E-mail externe avec le fichier de test EICAR en pièce jointe : la pièce jointe est bloquée et le message est mis en quarantaine (mode « Bloquer »).

ATTENTION **l'envoi peut échouer avant d'atteindre Microsoft 365.** Certains fournisseurs de messagerie analysent les pièces jointes à l'envoi : le message revient avec une erreur du type `552 5.2.0 Virus: Virus:EICAR`. Dans ce cas Safe Attachments n'a rien analysé et le test n'est pas concluant. Utiliser un expéditeur qui ne filtre pas à l'envoi. Une archive protégée par mot de passe passe plus facilement, mais ne peut pas être analysée : elle ne valide pas le blocage d'un programme malveillant.

INFO **À CONFIRMER : résultat du test EICAR.** Le blocage et la mise en quarantaine n'ont pas encore été observés sur le tenant de validation.

10.3 Anti-hameçonnage

N°	Étape	Action
C1	Utilisateurs à protéger	Direction, comptabilité et finances, administrateur système : comptes visés en priorité par l'usurpation d'identité (arnaque au président).
1	Chemin	security.microsoft.com → Courrier et collaboration → Stratégies et règles → Stratégies de menace → section « Stratégies » → Anti-hameçonnage. Seule la stratégie « Office365 AntiPhish Default (valeur par défaut) » existe au départ (état « Toujours activé », priorité « La plus faible »). Cliquer sur son nom : le panneau de détails présente « Valeur seuil et protection anti-hameçonnage » et « Actions ». Lien « Modifier les paramètres de protection ».
2	Seuil	Curseur « Seuil du courrier de hameçonnage » : valeur par défaut « 1 - Standard ». Le guide conserve cette valeur.
3	Utilisateurs protégés	Case « Permettre aux utilisateurs de protéger (0/350) » (décochée par défaut), puis lien « Gérer 0 expéditeur(s) » pour ajouter les comptes visés en C1 (350 utilisateurs au maximum).
4	Domaines	Case « Activer les domaines à protéger (0) » (décochée par défaut), puis lien « Gérer 0 domaine(s) personnalisé(s) » pour ajouter les domaines du client.
5	Intelligence	« Activer la veille des boîtes aux lettres (recommandé) » : coché par défaut. « Activer l'intelligence pour la protection contre l'emprunt d'identité (recommandé) » : décoché par défaut, à cocher (la veille des boîtes aux lettres doit être active).
6	Usurpation	« Activer la veille contre l'usurpation d'identité (recommandé) » : coché par défaut.

N°	Étape	Action
7	Action	Section « Actions », lien « Modifier les actions » (page « Modifier les actions », bloc « Actions de message »). Dans la stratégie par défaut, les trois listes « Si un message est détecté comme une usurpation d'identité d'un utilisateur », « ... d'un domaine » et « Si la veille des boîtes aux lettres détecte un utilisateur dont l'identité a été usurpée » sont grisées sur « N'appliquer aucune action » : elles ne deviennent modifiables qu'après avoir activé les utilisateurs ou domaines à protéger (étapes 3 à 5). Restent modifiables : « Respecter la stratégie d'enregistrement DMARC lorsque le message est détecté comme usurpant une identité » (coché), « Si ... DMARC est défini sur p=quarantine » → « Mettre le message en quarantaine » (stratégie `DefaultFullAccessPolicy`), « ... p=reject » → « Rejeter le message », « Si le message est détecté comme spoof par spoof intelligence » → « Déplacer le message vers les dossiers Email indésirable des destinataires ». Bloc « Conseils de sécurité et indicateurs » : « Afficher le conseil de sécurité de premier contact (recommandé) » décoché, « Afficher (?) des expéditeurs non authentifiés pour l'usurpation d'identité » coché, « Afficher la balise « via » » coché. Recommandation du guide : choisir la mise en quarantaine pour les actions d'usurpation d'identité d'un utilisateur et d'un domaine. Les valeurs proposées par ces listes grisées n'ont pas été relevées sur la stratégie par défaut.

10.4 Anti-spam et quarantaine

N°	Étape	Action
1	Politiques par défaut	Les politiques anti-spam et anti-programmes malveillants par défaut sont un bon point de départ pour une PME : vérifier seulement leur état.
2	Anti-spam	Stratégies de menace → « Logiciel anti-courrier indésirable ». Trois stratégies, toutes « Toujours activé », priorité « La plus faible » : « Stratégie entrante anti-courrier indésirable », « Stratégie de filtre de connexion » et « Stratégie sortante anti-courrier indésirable » (noms tronqués à l'écran). Vérifier seulement leur état.
3	Anti-programmes malveillants	Stratégies de menace → « Logiciel anti-programme malveillant ». Une stratégie « Default (valeur par défaut) », « Toujours activé », priorité « La plus faible ». Vérifier seulement son état.
4	Quarantaine	Stratégies de menace → section « Règles » → « Stratégie de mise en quarantaine ». Trois stratégies prédéfinies : `DefaultFullAccessPolicy`, `AdminOnlyAccessPolicy`, `DefaultFullAccessWithNotificationPolicy`. L'icône d'engrenage au-dessus de la liste ouvre « Paramètres de notification de mise en quarantaine » : « Nom d'affichage de l'expéditeur », « Spécifier l'adresse de l'expéditeur » (adresse du domaine de l'organisation), « Objet », « Clause d'exclusion de responsabilité », « Choisir la langue » (bouton « Ajouter »), « Utiliser le logo de ma société », et « Envoyer des notifications de courrier indésirable à l'utilisateur final » avec trois choix : « Dans un délai de 4 heures », « Quotidien » (affiché à l'ouverture), « Hebdomadaire ». Le libellé exact de la section « Règles » de la page « Stratégies de menace » est à confirmer (la page affiche une section « Règles » avec « Listes verte/rouge du client », « Paramètres d'authentification des e-mails », « Remise avancée »).

Partie 11 : Alertes et surveillance

11.1 Notifications par e-mail

N°	Étape	Action
C1	Objectif	Recevoir une notification pour les alertes de gravité élevée (et moyenne selon le besoin) : une alerte non vue retarde la détection d'un incident. Ces notifications contribuent à la détection et à la documentation des incidents. L'annonce d'une violation au PFPDT (art. 24) reste une décision et une procédure de l'organisation.
1	Chemin	security.microsoft.com → Paramètres (Installation et configuration) → Microsoft Defender XDR → Notifications par e-mail. Trois onglets : « Incidents », « Actions », « Analyse des menaces ». Une règle « Default incidents notification » existe déjà dans l'onglet « Incidents ».
2	Créer	Onglet « Incidents » → menu « ... » → « Ajouter une règle de notification d'incident ». L'assistant « Créer une règle de notification » compte quatre pages : Informations de base, Paramètres de notification, Destinataires, Règle de révision.
3	Nom	Page « Informations de base » : « Nom » obligatoire (le texte « Nouvelle stratégie » affiché est un exemple grisé, pas une valeur), « Description » facultative. Nom proposé : `NOTIF-Incidents-[Nom du client]`.
4	Paramètres	Page « Paramètres de notification » : cases « Envoyer une seule notification par incident », « Inclure le nom de l'organisation dans le courrier », « Inclure un lien de portail spécifique au locataire » (toutes décochées par défaut). Listes « Sources » et « Gravité de l'alerte » (obligatoires), bouton « Ajouter un service ».
5	Sources	Liste « Sources » : regroupe notamment « Microsoft Defender for Cloud Apps », « Defender XDR » et « Microsoft Defender pour point de terminaison » (EDR, Antivirus, SmartScreen, Tiers, Indicateur de menace) ; la liste est plus longue. Cocher les sources utiles au client.
6	Gravité	Liste « Gravité de l'alerte » : Information, Faible, Moyen, Élevé. Il n'existe pas de niveau « Critique » dans cette liste : cocher « Élevé » au minimum, « Moyen » si le client peut traiter ce volume.
7	Destinataires	Page « Destinataires » : « Adresse e-mail du destinataire » + bouton « Ajouter », bouton « Envoyer un e-mail de test » (actif après ajout). Au moins un destinataire est obligatoire (message « Au moins un destinataire doit être défini »). Saisir le compte administrateur, et l'équipe de sécurité si elle existe.
8	Validation	Page « Règle de révision » : récapitulatif (Informations de base, Paramètres de notification avec « Groupes d'appareils », Sources avec colonnes « Source », « Source de détection », « Gravité », Destinataires) → bouton « Envoyer ».
9	Intune	Notifications de non-conformité : intune.microsoft.com → Appareils → Conformité → Notifications. La page « Créez ou modifiez des modèles de messages de notification » liste les modèles (colonnes « Nom d'affichage », « Dernière modification ») et propose « Créer une notification ». Un modèle s'utilise ensuite dans l'action « Envoyer un e-mail à l'utilisateur final » d'une stratégie de conformité (voir Partie 8.4).

CONSEIL **test.** Déclencher le fichier de test EICAR sur un poste géré : relever le délai de réception de la notification lors de la validation terrain.

11.2 Tableau de bord Defender XDR

N°	Étape	Action
1	Incidents	security.microsoft.com → Enquête et réponse → Incidents et alertes → Incidents. Vue des alertes corrélées, à traiter en priorité. La page propose un filtre « État : Nouveau, En cours » par défaut, la liste « nom de l'incident », « ID d'incident », « Score de priorité », et deux cartes de synthèse : « Interruptions des attaques » et « Incidents à plusieurs alertes ».
2	Alertes	Enquête et réponse → Incidents et alertes → Alertes (le même sous-menu contient « Alertes de messagerie et de collaboration »). Vue des alertes par gravité.
3	Appareils	Ressources → Appareils : page « Inventaire des appareils ». Onglets « Tous les appareils », « Ordinateurs et appareils mobiles », « Périphérique réseau », avec les compteurs « Total », « Ressources critiques », « Risque élevé », « Exposition élevée », « Non intégré » et « Nouvellement découvert ». Le portail peut aussi afficher un bandeau sur les appareils qui utilisent encore Microsoft Monitoring Agent (MMA).
4	Courrier et collaboration	Menu « Courrier et collaboration » : « Enquêtes », « Explorateur », « Détections en temps réel », « Révision », « Campagnes », « Suivi des menaces », « Suivi de messages Exchange », « Stratégies et règles ». Les entrées disponibles dépendent de la licence ; le contenu de chaque page pour Safe Links et Safe Attachments n'a pas été relevé : à confirmer.

11.3 Niveau de sécurité Microsoft (Secure Score)

N°	Étape	Action
1	Chemin	security.microsoft.com → Niveau de sécurité Microsoft (la page affiche aussi le titre « Secure Score » en anglais). Onglets : « Vue d'ensemble », « Actions recommandées », « Historique », « Métriques et tendances ». La vue d'ensemble donne le pourcentage global, les points gagnés sur le total, une courbe d'évolution et la « Répartition des points par » catégorie : Identité, Données, Appareil, Applications.
2	Objectif	Relever le score avant et après déploiement et documenter l'écart dans le dossier du client. Une valeur cible chiffrée sera proposée après mesure sur des tenants réels.

Partie 12 : Intégration Entra ID, CA-04 et CA-08

CA-04 et CA-08 ont été créées en mode Rapport dans le guide Entra ID P1 (Parties 6 et 9). Cette partie les fait passer en Application, seulement après les vérifications ci-dessous.

12.1 CA-04, Token Protection

N°	Étape	Action
C1	Politique	`CA-04-Token-Protection-Windows`, créée dans le guide Entra ID P1 : ressources Exchange Online, SharePoint Online et Microsoft Teams Services ; plateforme Windows ; clients « Applications mobiles et clients de bureau » seulement ; navigateurs exclus.
C2	Prérequis	Appareils Windows joints à Entra, joints hybrides ou inscrits, avec des clients à jour. Appareils non supportés exclus par un filtre d'appareil : Windows 365 joint à Entra, hôtes de session Azure Virtual Desktop joints à Entra, Autopilot en mode self-deploying, inscription en masse.

N°	Étape	Action
1	Analyser	entra.microsoft.com → Entra ID → Accès conditionnel → menu « Supervision » → « Journaux de connexion » (page « Événements de connexion »). Onglets « Connexions utilisateur (interactives) » et « Connexions utilisateur (non interactives) », filtre « Plage de dates » (24 dernières heures par défaut : l'élargir pour couvrir l'usage normal). Examiner les connexions évaluées par CA-04 en mode Rapport et chercher les échecs, notamment le code `signInSessionStatusCode` 1003. Dans le détail d'une connexion, l'onglet « Accès conditionnel » donne le résultat de la politique (voir le guide Entra ID P1).
2	Activer	entra.microsoft.com → Entra ID → Accès conditionnel → CA-04 → « Activer une stratégie » : passer de « Rapport uniquement » à « Activé » (groupe pilote d'abord) → Enregistrer.
3	Tester	Sur un poste Windows du groupe pilote : Outlook, OneDrive et Teams (applications natives) fonctionnent. Le détail de la connexion montre la politique et le contrôle de session appliqués.

INFO Token Protection ne teste pas la conformité de l'appareil. La conformité relève de CA-08.

12.2 CA-08, Exiger un appareil conforme

N°	Étape	Action
C1	Prérequis	Politiques de conformité déployées (Partie 8) et appareils en statut « Conforme ». Mobiles inclus : sans politique de conformité iOS et Android, ces appareils seraient bloqués.
1	Vérifier	intune.microsoft.com → Appareils → Windows → Windows appareils : colonne « Conformité » (valeurs « Conforme », « Non conforme », « Non évalué »). Tous les appareils cibles doivent être « Conforme ». Un appareil « Non évalué » (par exemple un appareil géré par MDE seulement, sans inscription Intune) ne satisfait pas CA-08 : l'inscrire ou l'exclure. Examiner ensuite les résultats de CA-08 en mode Rapport pendant 7 à 14 jours : Accès conditionnel → menu « Supervision » → « Journaux de connexion ».
2	Activer	entra.microsoft.com → Entra ID → Accès conditionnel → `CA-08-Exiger-Appareil-Conforme` → « Utilisateurs » → « Exclure » : vérifier que `GRP-CA-BreakGlass` est bien exclu → « Activer une stratégie » : « Activé » → Enregistrer.
3	Test de blocage	Sur un poste de test : désactiver temporairement BitLocker, attendre le passage à « Non conforme », puis se connecter à Exchange : accès refusé par CA-08. Réactiver BitLocker : conformité restaurée.
4	Test d'accès	Appareil conforme : accès accordé.

CONSEIL **documentation.** Consignez la date d'activation de CA-04 et CA-08 dans le registre du client.

Partie 13 : Tests et validation

Test	Scénario	Résultat attendu
T1	Inscription Windows	Poste inscrit dans Intune, statut Géré. Membre de `GRP-Appareils-Windows` uniquement. Politiques appliquées.
T2	BitLocker	Chiffrement actif. Clé de récupération visible dans Entra ID → Appareils.

Test	Scénario	Résultat attendu
T3	USB bloquée	Clé non autorisée : accès refusé. Clé autorisée : accès accordé.
T4	Antivirus (EICAR)	Fichier de test bloqué, alerte visible dans Defender XDR.
T5	Notification e-mail	L'alerte EICAR déclenche une notification sur le compte administrateur.
T6	Safe Links	URL réécrite dans l'e-mail reçu (case « Ne réécrivez pas les URLs... » décochée, voir 10.1). Contrôler l'adresse réelle du lien et l'en-tête `X-MS-Exchange-AtpMessageProperties`. Réécriture observée sur le tenant de validation le lendemain de la création de la stratégie (voir 10.1).
T7	Safe Attachments	Pièce jointe EICAR bloquée, message en quarantaine (mode « Bloquer », voir 10.2). Si l'expéditeur refuse l'envoi (erreur `552 5.2.0`), le test n'est pas concluant.
T8	AIR et Centre d'actions	Les actions automatisées apparaissent dans le Centre d'actions. Comportement exact relevé sur le tenant.
T9	LAPS	Mot de passe administrateur local lisible dans Entra ID, accepté sur le poste. Après rotation manuelle, l'ancien est refusé. Consultation visible dans les journaux d'audit.
T10	ASR	En mode Audit, un comportement ciblé (par exemple macro Office de test) apparaît dans le rapport sans être bloqué. Après passage en Blocage, il est bloqué.
T11	Conformité Windows	Appareil conforme : statut « Conforme ». Après désactivation de BitLocker : « En période de grâce » aussitôt (stratégie en « Non conforme » dans la page de conformité de l'appareil), puis « Non conforme » à l'issue du délai de grâce (validé sur le tenant de validation avec 3 jours : badge rouge « Non conforme » sur la fiche de l'appareil).
T12	Conformité mobile	iOS et Android inscrits : statut de conformité correct, affectés au bon groupe. Appareil non conforme : accès refusé après CA-08.
T13	Remote Help	Si déployé : session établie, visible dans l'onglet « Séances d'Assistance à distance ». Mode sans utilisateur testé seulement s'il est disponible.
T14	Mises à jour	Anneau Pilote reçoit les mises à jour avant l'anneau Production.
T15	CA-04	Poste Windows pilote : applications natives fonctionnent, politique et contrôle de session visibles dans les journaux.
T16	CA-08	Appareil non conforme : accès refusé. Appareil conforme : accès accordé.
T17	Niveau de sécurité	Niveau de sécurité Microsoft relevé avant et après, écart documenté.

Checklist de remise client

☐	Action	Vérification	nLPD
☐	Groupes `GRP-Appareils-Windows`, `GRP-Appareils-iOS`, `GRP-Appareils-Android` créés et peuplés	Entra ID → Groupes	
☐	Connecteur Intune → Defender activé	Intune → Connecteurs	art. 8
☐	Appareils inscrits et dans le bon groupe	Intune → Appareils	
☐	BitLocker actif, clés dans Entra ID	Entra ID → Appareils → Clés	art. 8
☐	Device Control USB configuré et testé	Intune → Sécurité du point de terminaison	art. 8
☐	EDR : postes intégrés	Defender XDR → Appareils	art. 8
☐	Antivirus et Tamper Protection actifs	Intune → Sécurité du point de terminaison	art. 8

☐	Action	Vérification	nLPD
☐	Règles ASR en Blocage après période d'audit	Intune → Réduction de la surface d'attaque	art. 8
☐	Windows LAPS actif, lecture limitée, revue des consultations planifiée	Entra ID → Appareils	art. 8
☐	SmartScreen et Enhanced Phishing Protection (Windows 11)	Intune → Profils de configuration	art. 8
☐	Filtrage de contenu web configuré (politique unique), exceptions documentées	Defender XDR → Paramètres	art. 8
☐	AIR : Centre d'actions suivi, responsable désigné	Defender XDR → Centre d'actions	art. 8
☐	Gestion des vulnérabilités : recommandations critiques traitées	Defender XDR → Vulnérabilités	art. 8
☐	Conformité Windows, iOS et Android déployées	Intune → Conformité	art. 8
☐	Retrait des appareils non conformes : validation administrative documentée	Intune	art. 8
☐	Windows Hello Entreprise déployé	Intune → Inscription Windows	art. 8
☐	Windows Update for Business : deux anneaux	Intune → Anneaux de mise à jour	art. 8
☐	Messagerie mobile configurée (Outlook mobile recommandé sur Android)	Appareils mobiles	
☐	Safe Links, Safe Attachments, anti-hameçonnage configurés	security.microsoft.com	art. 8
☐	Notifications e-mail critique et élevée configurées	Defender XDR → Paramètres	art. 8
☐	CA-04 et CA-08 passées en Application après analyse du mode Rapport	Entra ID → Accès conditionnel	art. 8
☐	Procédure d'annonce des violations (art. 24) documentée par le client	Registre de sécurité	art. 24
☐	Tests T1 à T17 validés et documentés	Dossier de remise client	

Annexe A : Glossaire

Terme	Définition
AIR	Investigation et remédiation automatisées (Auto-Investigation and Remediation). Réponse automatisée de Defender aux menaces détectées. Intégrée à l'antivirus depuis l'évolution décrite par Microsoft.
APNs	Apple Push Notification service. Certificat requis pour gérer les appareils iOS par Intune, à renouveler chaque année.
ASR	Attack Surface Reduction. Règles qui bloquent des comportements utilisés par les malwares (macros, scripts, vol d'identifiants).
Autopilot	Provisionnement automatique d'un poste Windows au premier démarrage, par Intune.
BitLocker	Chiffrement de disque natif de Windows. Clé de récupération stockée dans Entra ID.
BitLocker To Go	Extension de BitLocker aux supports amovibles.
Centre d'actions	Interface Defender XDR qui regroupe les actions automatisées et en attente.
CVE	Common Vulnerabilities and Exposures. Identifiant standard d'une faille connue.
Device Control	Contrôle des périphériques (USB, imprimantes, Bluetooth) par Intune.
EDR	Endpoint Detection and Response. Surveillance comportementale, isolation et investigation sur les postes.
EICAR	Fichier de test antivirus standardisé, inoffensif.
Enhanced Phishing Protection	Fonction de Windows 11 qui avertit l'utilisateur qui saisit son mot de passe Windows dans une application non approuvée.
LAPS (Windows LAPS)	Local Administrator Password Solution. Mot de passe administrateur local unique par poste, renouvelé automatiquement.
Network Protection	Extension de SmartScreen à toutes les connexions réseau du poste.
PFPDT	Préposé fédéral à la protection des données et à la transparence, autorité de contrôle suisse.
Remote Help	Prise en main à distance intégrée à Intune, avec journalisation. Licence complémentaire à vérifier.
Safe Attachments	Analyse des pièces jointes dans un bac à sable avant livraison.
Safe Links	Réécriture et vérification des URL des e-mails au moment du clic.
Tamper Protection	Empêche une application ou un script de désactiver Defender.
Wipe sélectif (retrait)	Suppression des données et applications de l'entreprise sans effacer les données personnelles. Soumis à validation administrative.
Web Content Filtering	Filtrage de catégories de sites web par Defender.

Annexe B : Checklist MVC complète avec références nLPD

Prérequis et inscription

☐	Action	Portail / Chemin	nLPD
☐	Groupes `GRP-Appareils-Windows`, `GRP-Appareils-iOS`, `GRP-Appareils-Android`	entra.microsoft.com → Groupes	
☐	Connecteur Intune → Defender activé	Intune → Administration des clients	art. 8

☐	Action	Portail / Chemin	nLPD
☐	Inscription automatique Windows activée	Intune → Appareils → Inscription Windows	
☐	APNs créé, date d'expiration documentée	Intune → Appareils → iOS	
☐	Google Play géré lié	Intune → Appareils → Android	
☐	Appareils inscrits et dans le bon groupe	Intune → Appareils	

Chiffrement et contrôle des périphériques

☐	Action	Portail / Chemin	nLPD
☐	BitLocker (algorithme et étendue choisis), clés dans Entra ID	Intune → Sécurité du point de terminaison → Chiffrement de disques	art. 8
☐	BitLocker To Go configuré (si USB autorisées)	Intune → Sécurité du point de terminaison → Chiffrement de disques	art. 8
☐	Device Control USB testé	Intune → Réduction de la surface d'attaque	art. 8

Endpoint Security

☐	Action	Portail / Chemin	nLPD
☐	EDR : postes intégrés	Intune → Détection et réponse des points de terminaison	art. 8
☐	Antivirus et Tamper Protection	Intune → Antivirus	art. 8
☐	Pare-feu : trois profils actifs	Intune → Pare-feu	art. 8
☐	ASR : Blocage après période d'audit	Intune → Réduction de la surface d'attaque	art. 8
☐	Network Protection : Blocage après audit	Intune → Réduction de la surface d'attaque	art. 8
☐	Windows LAPS, lecture limitée, revue des consultations	Intune → Protection du compte ; Entra ID → Appareils	art. 8

Navigation web, investigation, vulnérabilités

☐	Action	Portail / Chemin	nLPD
☐	SmartScreen : Blocage	Intune → Profils de configuration	
☐	Enhanced Phishing Protection (Windows 11)	Intune → Profils de configuration	art. 8
☐	Filtrage de contenu web : politique unique, exceptions documentées	security.microsoft.com → Paramètres	
☐	AIR : Centre d'actions suivi	security.microsoft.com → Centre d'actions	art. 8
☐	Gestion des vulnérabilités : recommandations critiques traitées	security.microsoft.com → Vulnérabilités	art. 8

Conformité et profils

☐	Action	Portail / Chemin	nLPD
☐	Conformité Windows	Intune → Appareils → Conformité	art. 8

☐	Action	Portail / Chemin	nLPD
☐	Conformité iOS	Intune → Appareils → Conformité	art. 8
☐	Conformité Android	Intune → Appareils → Conformité	art. 8
☐	Actions de non-conformité, retrait validé par un administrateur	Intune → Conformité → Actions	art. 8
☐	Windows Hello Entreprise	Intune → Inscription Windows	art. 8
☐	Windows Update for Business : deux anneaux	Intune → Anneaux de mise à jour	art. 8
☐	Messagerie mobile (Outlook mobile sur Android)	Intune → Profils et stratégies d'application	

Defender for Office 365

☐	Action	Portail / Chemin	nLPD
☐	Liens fiables, tous les utilisateurs	security.microsoft.com	art. 8
☐	Pièces jointes fiables, Blocage avec livraison dynamique	security.microsoft.com	art. 8
☐	Anti-hameçonnage, utilisateurs protégés	security.microsoft.com	art. 8
☐	Anti-spam et quarantaine utilisateur	security.microsoft.com	

Alertes et intégration Entra ID

☐	Action	Portail / Chemin	nLPD
☐	Notifications e-mail critique et élevée	security.microsoft.com → Paramètres	art. 8
☐	CA-04 en Application après analyse	entra.microsoft.com → Accès conditionnel	art. 8
☐	CA-08 en Application après analyse	entra.microsoft.com → Accès conditionnel	art. 8
☐	Procédure d'annonce des violations documentée par le client	Registre de sécurité	art. 24
☐	Tests T1 à T17 documentés	Dossier de remise client	

Annexe C : Références nLPD, mesures techniques couvertes

Ce tableau peut servir de pièce justificative lors d'un audit du PFPDT. Référence : **nLPD RS 235.1**, en vigueur depuis le 1er septembre 2023. Délai d'annonce d'une violation : **« dès que possible »** (pas de délai fixe de 72 heures comme dans le RGPD). Autorité : **PFPDT**. Ces mesures techniques contribuent à la sécurité des données au sens de la nLPD ; elles ne garantissent pas à elles seules la conformité de l'entreprise.

Article nLPD	Obligation	Mesure technique déployée	Section
art. 8 al. 1	Mesures techniques adaptées au risque	Antivirus, Tamper Protection, ASR, EDR	Partie 4
art. 8 al. 1	Protection des données au repos	BitLocker et BitLocker To Go	§3.1, §3.2
art. 8 al. 1	Prévention de l'exfiltration physique	Device Control USB	§3.3
art. 8 al. 1	Réduction de la surface d'attaque	ASR, Network Protection, SmartScreen	§4.5, §4.6, Partie 5

Article nLPD	Obligation	Mesure technique déployée	Section
art. 8 al. 1	Limitation du mouvement latéral	Windows LAPS	§4.7
art. 8 al. 1	Authentification forte des postes	Windows Hello Entreprise	§9.1
art. 8 al. 1	Contrôle d'accès par état de sécurité	Conformité Intune et CA-08	Parties 8 et 12
art. 8 al. 1	Inventaire et correction des vulnérabilités	Gestion des vulnérabilités	Partie 7
art. 8 al. 1	Maintien à jour	Windows Update for Business	§9.2
art. 8 al. 1	Protection de la messagerie	Safe Links, Safe Attachments, anti-hameçonnage	Partie 10
art. 8 al. 1	Détection et documentation des incidents (contribution)	AIR, Centre d'actions, notifications e-mail	§6.1, §11.1
art. 8 al. 2	Éviter les violations de la sécurité des données (la loi ne prescrit pas de mesure nommée)	L'ensemble des mesures ci-dessus y contribue	Parties 3 à 10
art. 24	Annonce des violations de la sécurité des données au PFPDT	Procédure organisationnelle du client. Les journaux et alertes de ce guide facilitent la détection et la documentation, sans remplacer l'annonce.	Checklist
art. 6 al. 2	Proportionnalité (appareils personnels)	User Enrollment iOS et profil de travail Android : pas d'accès aux données personnelles	Partie 2

Annexe D : Adaptations sectorielles

Secteur	Point de rupture	Adaptation recommandée
PME générique	Aucun	MVC tel quel.
Fiduciaire / comptabilité	Logiciels comptables anciens (Banana, Sage) bloqués par ASR	Repérer les faux positifs en mode Audit, ajouter des exclusions documentées.
Cabinet médical	Données médicales très sensibles	Device Control : blocage total. Score de risque Defender : « Aucun risque » exigé. Safe Attachments : vérifier que le délai de livraison dynamique est acceptable.
Avocats / notaires	Confidentialité maximale	Device Control : blocage total. Filtrage web : politique unique pour toute l'organisation ; le blocage de services précis (Dropbox, WeTransfer) n'est pas couvert par les catégories relevées, à valider. Enhanced Phishing Protection activée.
Agence de communication	Appareils personnels, réseaux sociaux métier	Device Control assoupli pour les postes créatifs. Filtrage web : ne pas bloquer la catégorie « Réseaux sociaux » (la politique est unique pour toute l'organisation).
Architecture / ingénierie	Fichiers volumineux (plans, BIM)	Safe Attachments : valider avec le client la tolérance au délai pour les gros fichiers.

Annexe E : Différences POC et production

Point	POC (test)	Production (recommandé)
Inscription Windows	Manuelle, postes existants	Autopilot pour les nouveaux postes
BitLocker	TPM sans PIN	TPM + PIN pour la direction et les administrateurs
Device Control USB	Blocage total ou liste blanche simple	Liste blanche par identifiant fabricant et produit
ASR	Audit 14 jours, puis Blocage	Audit, validation sur un groupe pilote, puis Blocage règle par règle
AIR	Suivi occasionnel du Centre d'actions	Revue hebdomadaire documentée du Centre d'actions
Score de risque Defender (conformité)	« Faible » accepté	« Aucun risque » pour la direction et les administrateurs
LAPS	Lecture par l'administrateur général	Rôle dédié, revue périodique des journaux d'audit
Gestion des vulnérabilités	Revue mensuelle manuelle	Tâches de remédiation Intune
Alertes	E-mail administrateur uniquement	Liste de l'équipe de sécurité et ticketing si disponible
Filtrage web	Catégories malveillantes seulement	Catégories validées par la direction
APNs iOS	Géré manuellement	Rappel de renouvellement annuel au calendrier de l'administrateur
Retrait des appareils non conformes	Validation ad hoc	Procédure écrite de validation, notamment pour le BYOD

Annexe F : Licences

ATTENTION les prix et l'inclusion de fonctionnalités dans les plans E3 et E5 évoluent. Ce guide ne publie volontairement aucun prix. Vérifiez la composition des licences sur la page officielle Microsoft et auprès du revendeur avant tout engagement.

Fonctionnalité	Dans Microsoft 365 Business Premium	Remarque
Intune Plan 1 (MDM, MAM)	Oui	
Entra ID P1 (accès conditionnel, MFA, SSPR)	Oui	
Defender for Business (EDR pour PME)	Oui	
Defender for Office 365 Plan 1	Oui	
Windows LAPS, Quick Assist	Natifs de Windows	
Remote Help	À vérifier	Licence complémentaire selon le tenant (voir Partie 7bis)
Intune Plan 2 et fonctions Intune Suite (par exemple Endpoint Privilege Management, Cloud PKI)	À vérifier	Add-on ou plan supérieur
Entra ID P2 (PIM, Identity Protection), Defender for Cloud Apps	À vérifier	Hors périmètre MVC
Limite d'utilisateurs	300 utilisateurs maximum	